FIPS 140-3
Cryptographic Module Validation Program Management Manual

(Date 4/09/2026)

Version 2.7

National Institute of Standards and Technology and
Canadian Centre for Cyber Security

Revision History

Version	Date	Comment
1.0	9/21/2020	First draft release for FIPS 140-3 program
1.1	7/13/2022	Second draft release. Major rewrite.
1.2	12/23/2022	Third draft release. Updates to address feedback submitted July 2022.
2.0	12/06/2023	Final version. Updates to address feedback submitted February 2023 and final review comments. • Final version (2.0) rather than a draft. • Minor revisions to RFG text and template (2.5). • New statement on labs responsibility to demonstrate full compliance for approved cryptographic claims, including requirements not covered by CAVP tests (2.6.2). • Included Triage text (4.1.1.2). • ECR (3.2.8) and HOLD (4.4.3) policies. • Clarified what is a permitted change while Pending Review (4.3.5) and or during Coordination (4.3.6). • Small clarifications in the ESV section (4.9). • Scenario definitions including introducing limited scenario combinations (and a summary table of permitted combinations in 7.1.15), and regression testing requirements (7.1). • Added IG reference to better define “security” as it relates to NSRL (7.1.5) and UPDT (7.1.10). • Incorporate remote testing guidance (7.4). • Moved *Module count definition* (7.8) to a CMVP webpage.
2.1	02/29/2024	4.3.6 (Changes while in Coordination): Provided new options and guidance for changes while in Coordination. 7.1.15 (Additional Comments): 1 and 2 were clarified when Security Levels are changed.
2.2	04/19/2024	3.2.8 (Suspension, Denial and Revocation of Accreditation): Added “Quality errors” into the second points category. 4.3.5 (Resubmission while in Pending Review) & 4.3.6 (Changes

		while in Coordination): Small clarifications. 4.8 (Validation Revocation or Historical): Clarified Revocation and Historical guidance. 7.1 (Submission Scenarios): Minor grammatical / typographical corrections.
2.3	12/17/2024	General clean up (e.g., grammar, formatting, references, navigation including changing all "shall" to "must" outside of Section 7 for consistency). 2.4 (CMVP Points of Contact): Added email categories for general or CSTL usage. 2.5.2 (Request for Guidance Format): Updated RFG Template and added reference to IG template. 3.2.4 (Relocation of a CSTL): Customer ID may change if change in location. 3.2.8 (Extended Cost Recovery): Significant revision to remove duplication and reduce ambiguity by specifying ECR categories with examples in a new table. 3.2.9 (Suspension of Accreditation): Revised text around suspension. 4.3.3 (Request for Transition Period Extension): New section. 6.2 (Suggested Tools for Physical Testing): Added text in the first paragraph around calibration and a few other minor changes. 7.1.1 (Requirements for all revalidations): Updated guidance for new CSTLs. 7.1.2.1 (Interim Validation): New section. 7.1.5 (Non-Security Relevant (NSRL)): Added 'd' on minimum test requirements. 7.8 (Module definitions for same certificates): Added "self-tests".
2.4	05/07/2025	General: minor formatting, non-technical content and reference updates. 1.2 (Purpose of the CMVP Management Manual): merged content with section 1.3 (Applicability and Scope). 1.5 (Use of Validated Products): merged content with content from the CMVP webpage. 7.1.10 (Update (UPDT)): Allow UPDT to combine with VUP and VAOE. 7.1.14 (Submission Scenario Summary Table): Added "Code

<table>
<tr><td></td><td></td><td>changes” and “CAVP” columns and footnotes.

7.2.1. (Vendor Affirmation of Security Functions and Methods): some formatting changes and corrections to outdated/incorrect text.

7.4 (Remote Testing of Modules): Editorial fixes to HB references and added “third party” to 3c.</td></tr>
<tr><td>2.5</td><td>05/14/2025</td><td>7.1.13 (Physical Enclosure (PHYS)): Allow PHYS to combine with limited NSRL.</td></tr>
<tr><td>2.6</td><td>10/16/2025</td><td>4.3.5 (Resubmission while in Pending Review): Added PTSC to 1(c) with the same footnote as the OEUP.

4.3.6 (Changes while in Coordination): Small format changes so that it is clear where and when the summary of changes applies.

7.1.1 (Requirements for all revalidations): Provided an exception in bullet ‘a’ for VUP and VAOE submissions regarding design documentation and implementation for a new lab. In bullet ‘c’, added OEUP and PTSC as scenarios when the original test report is needed for a new lab. New bullet ‘l’ to address lab responsibility for revalidation scenarios.

7.1.2.2 (Br1 Update to Interim (INTU)): new section to describe this new submission scenario.

7.1.7: (Rebrand (RBND)): Clarified that any module type can be rebranded.

7.1.14 (Submission Scenario Summary Table): Added “Existing OEs Re-tested” column and footnote. Added INTU row. Updated Submission Process column.

7.8 (Module definitions for same certificates): Corrected “Design assurance” to “Life-cycle assurance” in number 10 since this was an artefact of FIPS 140-2.</td></tr>
<tr><td>2.7</td><td>04/09/2026</td><td>General: Updated to reflect changes to MIP states. i.e.,

<table><tr><th>Previous States</th><th>New States</th></tr><tr><td>Implementation Under Test</td><td>Implementation Under Test</td></tr><tr><td>Review Pending</td><td>Pending Review</td></tr><tr><td>Review Pending</td><td>Cost Recovery</td></tr><tr><td>In Review</td><td>Review</td></tr></table></td></tr>
</table>

		<table><tr><td>Coordination</td><td>Comment Resolution – Lab</td></tr><tr><td>Coordination</td><td>Comment Resolution – CMVP</td></tr><tr><td>Finalization</td><td>Finalization</td></tr><tr><td>On Hold</td><td>Hold</td></tr></table> 4.8 (ESV and RBG Processes): Renamed section 4.8 to include RBGs. Cleaned up 4.8 introduction paragraphs. Added SP 800-90C random bit generator (RBG) as a submission track through ESV. Added 4.8.1.1 (Entropy Source Validation Submission Types). In 4.8.2 (ESV Comment Remediation Process), added file naming conventions. In 4.8.3. (ESV Webpages) added references to EAR and PUD Templates and other documents. 7.1.3 (VUP): changes that can affect FIPS 140-3 requirements are NOT submitted as a VUP. 7.1.5 (NSRL): added ending paragraph to highlight that an NSRL can be submitted even if no code changes are made, if FIPS 140-3 assertions are affected. 7.1.11 (CVE): updated this scenario to include a new allowance for security relevant maintenance/bug fixes. 7.1.14 (Submission Scenario Summary Table): Removed “Submission Process” column and footnote due to constant WebCryptik updates that would make this column outdated. 7.1.15 (Additional Comments): Corrected number 4 to disallow ALG as part of a RBND. 7.8 (Module definitions for same certificates): Updated number 4 to reaffirm it applies to the entropy source if within the cryptographic boundary.

Table of Contents

Contents

1 INTRODUCTION 1

1.1 Background 1

1.2 Purpose of the CMVP Management Manual 1

1.3 Purpose of the CMVP 1

1.4 Purpose of the Cryptographic Algorithm Validation Program (CAVP) 2

1.5 Use of Validated Products 2

1.6 CMVP Management Manual Structure 2

1.7 CMVP Related Documents 3
1.7.1 FIPS 140-3 3
1.7.2 Security Requirements for Cryptographic Modules 3
1.7.3 Test requirements for cryptographic modules 4
1.7.4 NIST SP 800-140*x* 4
1.7.5 Implementation Guidance and Request For Guidance 5
1.7.6 Web Cryptik User Guide 5
1.7.7 CSTL Accreditation Standards 6
1.7.8 Page Links on the CMVP Website Main Page 6

2 CMVP MANAGEMENT 9

2.1 Introduction 9

2.2 Validation Authority 9

2.3 Programmatic Directives, Policies, Internal Guidance and Documentation 9

2.4 CMVP Points of Contact 9
2.4.1 Language of Correspondence 10

2.5 Request for Guidance from CMVP 10
2.5.1 Request for Guidance Details 11
2.5.2 Request for Guidance Format 12
2.5.3 Post Validation Inquiries 12

2.6 Roles and Responsibilities of Program Participants 13
2.6.1 Vendor 13
2.6.2 Cryptographic and Security Testing Laboratory 13
2.6.3 CMVP Validation Authorities 15
2.6.4 Validated Module User 15

2.7 CMVP Meetings 15
2.7.1 CSTL Manager Meetings 16

2.7.2 CMUF participation 16

2.8 Confidentiality of Information 17

3 CSTL PROCESSES 18

3.1 Accreditation of CMVP scopes for CSTLs 18
3.1.1 Accreditation Process for the CMVP scope 18

3.2 Maintenance of CSTL Accreditation 22
3.2.1 Proficiency of CSTL 22
3.2.2 Renewal of Accreditation 23
3.2.3 Ownership of a CSTL 23
3.2.4 Relocation of a CSTL 23
3.2.5 Change of Approved Signatories 23
3.2.6 Change of Key Laboratory Testing Staff 24
3.2.7 Monitoring Visits 24
3.2.8 Extended Cost Recovery 24
3.2.9 Suspension of Accreditation 26
3.2.10 Revocation of Scope 26

3.3 Confidentiality of Proprietary Information 26
3.3.1 Confidentiality of Proprietary Information Exchanged between NIST, CCCS and the CSTL 26
3.3.2 Non-Disclosure Agreement for Current and Former Employees 27

3.4 Code of Ethics for the CSTLs 27

3.5 Management of CMVP and CAVP Test Tools 27

4 CMVP PROCESSES 28

4.1 Cryptographic Module Validation Process Overview 28
4.1.1 Vendor, CSTL, and CMVP duties for Testing of the Cryptographic Module 28

4.2 Implementation Under Test (IUT) and Modules in Process (MIP) 31

4.3 Validation Submission Queue Processing 31
4.3.1 Full and Update Submission Validations 31
4.3.2 All other submissions 32
4.3.3 Request for Transition Period Extension 32
4.3.4 HOLD Status for Cryptographic Modules on the Modules In Process 32
4.3.5 Resubmission while in Pending Review 33
4.3.6 Changes while in Coordination 33
4.3.7 Validation Deadline 34

4.4 Validation when Test Reports are not Reviewed by both Validation Authorities 34
4.4.1 Controlled Unclassified Information 35

4.5 CMVP Fees 36
4.5.1 Cost Recovery Program (CR & ECR) 36
4.5.2 NIST Payment Policy 36
4.5.3 Invoice for a Report Submission 36

4.6 Flaw Discovery Handling Process 37

4.7 Historical or Revoked Validations 37

4.8 Entropy Source Validation (ESV) and Random Bit Generator (RBG) Processes 39
4.8.1.1 Entropy Source Validation Submission Types 39
4.8.1.2 Entropy Source Validation Submission Procedures 40
4.8.1.3 Entropy Source Validation Web Client 41
4.8.1.4 Entropy Source Validation Python Client 41
4.8.2 Entropy Source Validation Comment Remediation Process 42
4.8.3 Entropy Source Validation Webpages 43

4.9 CMVP Webpages 43
4.9.1 Official CMVP Website 43
4.9.2 Cryptographic Module Validation Lists 43
4.9.3 CMVP Certificate Page Links 44
4.9.3.1 Security Policy 45
4.9.3.2 Consolidated Validation Certificate 45
4.9.3.3 Vendor Link 45
4.9.3.4 Vendor Product Link 45
4.9.3.5 Algorithm Certificates 45
4.9.3.6 Validation History 45
4.9.4 Usage of FIPS 140-3 Logos 46

5 CMVP AND CAVP PROGRAMMATIC METRICS COLLECTION 47

5.1 Overview 47

5.2 Confidentially of the Collected Metrics Data 47

5.3 Collected Metrics 47

6 TEST TOOLS 48
6.1 Web Cryptik 48
6.2 Suggested Tools for Physical Testing 48

7 CMVP GENERAL TESTING AND REPORTING GUIDANCE 50

7.1 Submission Scenarios 50
7.1.1 Requirements for all revalidations 50
7.1.2 Full Submission (FS) 52
7.1.2.1 Interim Validation 52
7.1.2.2 Br1 Update to Interim (INTU) 52
7.1.3 Vendor Update (VUP) 53
7.1.4 Vendor Affirmed Operational Environment (VAOE) 53
7.1.5 Non-Security Relevant (NSRL) 53
7.1.6 Algorithm Update (ALG) 55
7.1.7 Operational Environment Update (OEUP) 56
7.1.8 Rebrand (RBND) 56
7.1.9 Port Sub Chip (PTSC) 57
7.1.10 Update (UPDT) 58
7.1.11 Common Vulnerabilities and Exposures (CVE) 59
7.1.12 Algorithm Transition (TRNS) 61
7.1.13 Physical Enclosure (PHYS) 64
7.1.14 Submission Scenario Summary Table 65

7.1.15 Additional Comments 66

7.2 CMVP requirements pertaining to testing and approved algorithms 68
7.2.1 Vendor Affirmation of Security Functions and Methods 69
7.2.2 Transitioning from vendor affirmed to CAVP Testing 69

7.3 Testing using Emulators and Simulators 70

7.4 Remote Testing of Modules 72

7.5 Partial validations and non-applicable areas 75

7.6 CMVP requirements for PIV validations 75

7.7 Module count definition 76

7.8 Module definitions for same certificates 76

7.9 Vendor or User Affirmation of Modules 76
7.9.1 **Vendor** 77
7.9.2 **User** 78

7.10 Operational Equivalency Testing for HW Modules 78

ANNEX A CMVP POST VALIDATION ISSUE ASSESSMENT PROCESS 82

Annex A.1 Addressing Security Relevant Issues 82

Annex A.2 Addressing CVE Relevant Vulnerabilities 83

ACRONYMS 84

List of Figures

Figure 1 - Roles, Responsibilities, and Output in the CMVP Process 13
Figure 2 - CSTL NVLAP scopes 18
Figure 3 - CSTL Accreditation Process 19
Figure 4- Cryptographic Module Testing and Validation Process 28
Figure 5- Annex A. Validation Issue Assessment Process 82

List of Tables

Table 1 - CAVP testing release dates and subsequent CMVP Transition dates 70
Table 2 - Equivalence Categories 79

1 Introduction

1.1 Background

The Canadian Centre for Cyber Security (CCCS) and the National Institute of Standards and Technology (NIST) announced the establishment of the Cryptographic Module Validation Program (CMVP) on July 17, 1995. The CMVP validates commercial cryptographic modules to Federal Information Processing Standard (FIPS) 140, NIST-recommended standards, and other cryptography-based standards. The CMVP is a government validation program that is jointly managed by NIST and CCCS. Cryptographic modules validated as conforming to FIPS 140 are used by Federal agencies for the protection of Controlled Unclassified Information (CUI) (Government of the United States of America) or Protected information (Government of Canada).

Vendors of commercial cryptographic modules use independent, National Voluntary Laboratory Accreditation Program (NVLAP) accredited Cryptographic and Security Testing (CST) laboratories to have their modules tested. The Cryptographic and Security Testing Laboratories (CSTL)s may perform all of the tests covered by the CMVP. The Validation Authority reviews laboratory reports, issues validation certificates, and participates in laboratory accreditations.

1.2 Purpose of the CMVP Management Manual

The purpose of the CMVP Management Manual is to provide effective management guidance for the CMVP, CST labs, and the vendors who participate in the program. Consumers who procure validated cryptographic modules may also be interested in the contents of this manual.

This manual outlines the management activities, processes, and responsibilities that have been assigned to the various participating groups. This manual includes administrative guidance. For technical aspects of the requirements of the referenced standards, please refer to the CMVP webpage and associated links (e.g., FIPS 140-3 IG and RFG Announcements).

1.3 Purpose of the CMVP

The purpose of the CMVP is to increase assurance of secure cryptographic modules through an established process.

Prior to CMVP, each office was responsible for assessing encryption products with no standardized requirements. This meant that each office needed some expertise in evaluating manufacturing practices for cryptographic equipment and vendors would have to support each office in their evaluation. With the establishment of the CMVP, a standards-based assessment could be uniformly applied and used across the federal governments and other organizations finding value in the use of validated cryptography.

CMVP validation is performed through conformance testing to requirements for cryptographic modules as specified in FIPS 140. Accredited third-party CSTLs perform independent assurance testing with CMVP oversight. CMVP is the Validation Authority, a joint initiative between the Government of Canada and the Government of the United States of America. For more

information about CMVP see: https://csrc.nist.gov/projects/cryptographic-module-validation-program.

1.4 Purpose of the Cryptographic Algorithm Validation Program (CAVP)

The purpose of the CAVP is to increase assurance of cryptographic algorithms through a testing process. Validation is achieved by testing the algorithm and comparing results to known or expected answers. Tests are to demonstrate compliance with cryptographic standards listed in SP 800-140C, SP 800-140D, and SP 800-140E. More information about CAVP can be found at: https://csrc.nist.gov/Projects/cryptographic-algorithm-validation-program.

1.5 Use of Validated Products

FIPS 140 requirements are applicable to all U.S. Federal agencies, but private sectors can use cryptographic modules validated to FIPS 140 for the protection of sensitive information. Federal agencies must use cryptographic-based security systems to provide adequate information security for all operations and assets as defined in 15 U.S.C. § 278g-3. Additionally, cryptographic modules must meet the requirements outlined in the FIPS 140 standards in order to comply with the FISMA mandate.

Non-validated cryptography is viewed as providing no protection to the information or data—in effect the data would be considered unprotected plaintext. If the agency specifies that the information or data be cryptographically protected, then FIPS 140 is applicable. In essence, if cryptography is required, then it must be validated.

Similarly, the CCCS *recommends* that GC departments and agencies use those validated cryptographic modules for the protection of Protected information.

1.6 CMVP Management Manual Structure

This manual is organized into the following sections:

Section 1 – Introduction provides an introduction and overview of the CMVP.

Section 2 – CMVP Management describes the management of the CMVP including the organization, administration, roles and responsibilities, and policies.

Section 3 – CSTL Processes describes the CSTL processes including accreditation, maintenance, and management of a laboratory.

Section 4 – CMVP Processes describes the various aspects of the cryptographic module validation process.

Section 5 – CMVP and CAVP Programmatic Metrics Collection.

Section 6 – Test Tools describes the necessary and recommended tools for use by the CSTLs.

Section 7 – CMVP General Testing and Reporting Guidance adds requirements to manage the CMVP testing program, minimizing retest and maximizing testing

flexibility while maintaining assurance.

Annex A –Validation Issue Assessment Process provides an overview how contentious issues over module previously validated are addressed.

1.7 CMVP Related Documents

FIPS 140 specifies the security requirements for a cryptographic module utilized within a security system protecting sensitive information in computer and telecommunication systems. The CMVP utilizes a set of documents, identified below, containing the security requirements and testing of those requirements that must be satisfied by a cryptographic module. CMVP also works with NVLAP to address CSTL accreditation requirements. A diagram of the relationships for the documents referenced below is available on the CMVP webpage (www.nist.gov/cmvp) under *CMVP FIPS 140-3 Related References*.

1.7.1 FIPS 140-3

Federal Information Processing Standards FIPS 140-3 identifies the CMVP, a joint effort of the US and Canadian governments, as the validation authority for implementing a program utilizing the ISO/IEC 19790:2012 requirements standard and ISO/IEC 24759:2017 derived test methods. The standard also established the CMVP technical requirements to be contained in NIST Special Publication (SP) 800-140, SP 800-140A, SP 800-140B, SP 800-140C, SP 800-140D, SP 800-140E, and SP 800-140F, and their latest revisions. These security requirements must be satisfied by a cryptographic module utilized within a security system protecting controlled unclassified information (hereafter referred to as sensitive information). This standard supersedes FIPS 140-2, Security Requirements for Cryptographic Modules, in its entirety. FIPS 140-3 is available on-line at https://doi.org/10.6028/NIST.FIPS.140-3.

Responsible Positions: NIST CMVP and CCCS CMVP Program Managers.

1.7.2 Security Requirements for Cryptographic Modules

ISO/IEC 19790:2012 (with Technical Corrigendum 1 in 2015) specifies the security requirements for a cryptographic module utilized within a security system protecting sensitive information in computer and telecommunication systems. This International Organization for Standardization, (ISO) standard defines different levels for cryptographic modules to provide for a wide spectrum of data sensitivity (e.g., low value administrative data, million-dollar funds transfers, life protecting data, personal identity information, and sensitive information used by government) and a diversity of application environments (e.g., a guarded facility, an office, removable media, and a completely unprotected location). The ISO/IEC Standard specifies four security levels with 11 requirement areas, each security level increasing security requirements over the preceding level.

The standard is typically reviewed by an ISO committee every three years for consideration of revision. Copies can be obtained from ISO.org. NIST made available a limited number of copies of ISO/IEC 19790:2012. To request a copy of ISO/IEC 19790:2012 and ISO/IEC 24759:2017 (see below), see the CMVP webpage, https://csrc.nist.gov/Projects/cryptographic-module-

validation-program/fips-140-3-standards.

Responsible Positions: ISO technical committee: ISO/IEC JTC 1/SC 27 Information security, cybersecurity and privacy protection.

1.7.3 Test requirements for cryptographic modules

ISO/IEC 24759:2017 specifies the methods to be used by accredited CSTLs to test whether the cryptographic module conforms to the requirements specified in ISO/IEC 19790:2012. The test requirements (TR) contains the security requirements from ISO/IEC 19790:2012, stated as a set of assertions (AS) (i.e., statements that must be true for the cryptographic module to satisfy the requirement of a given area at a given level). All assertions are direct quotations from ISO/IEC 19790:2012. Following each assertion is a set of information requirements that must be fulfilled by the vendor as vendor evidence (VE). These VEs describe the types of documentation or explicit information that the vendor must provide in order for the tester to determine conformance to the given assertion. Following each assertion and corresponding vendor information requirement is a set of test evidence (TE) that must be applied by the tester of the cryptographic module. These TEs instruct the tester as to what they must do in order to test the cryptographic module with respect to the given assertion. ISO/IEC 24759:2017 VE and TE requirements may be modified by the SP 800-140 set of documents and the FIPS 140-3 Implementation Guidance (IG).

Responsible Positions: ISO technical committee: ISO/IEC JTC 1/SC 27 Information security, cybersecurity and privacy protection.

1.7.4 NIST SP 800-140*x*

The current version of the following SPs can be found at: https://csrc.nist.gov/Projects/cryptographic-module-validation-program/fips-140-3-standards#sp . Each SP 800-140*x* document will be updated as needed, following the publication of a draft for public comment and resolution by the CMVP.

NIST SP 800-140 specifies the Test Requirements (TR) for Federal Information Processing Standard (FIPS) 140-3. SP 800-140 modifies the TE and/or VE requirements of ISO/IEC 24759:2017. As a validation authority, the CMVP may modify, add, or delete TEs and/or VEs as specified under section 5.2 of ISO/IEC 24759:2017. This NIST SP should be used in conjunction with ISO/IEC 24759:2017 as it modifies only those requirements identified in this document.

NIST SP 800-140A modifies the vendor documentation requirements of ISO/IEC 19790:2012 Annex A. As a validation authority, the CMVP may modify, add, or delete VEs and/or TEs as specified under section 5.2 of ISO/IEC 19790:2012. This document should be used in conjunction with ISO/IEC 19790:2012 Annex A and ISO/IEC 24759:2017 paragraph 6.13 as it modifies only those requirements identified in this document.

NIST SP 800-140Br1 is to be used in conjunction with ISO/IEC 19790:2012 Annex B and ISO/IEC 24759:2017 6.14. The SP modifies only those requirements identified in this document. SP 800-140B also specifies the content of the tabular and graphical information required in ISO/IEC 19790:2012 Annex B. As a validation authority, the CMVP may modify, add, or delete VE and/or TE specified under paragraph 6.14 of ISO/IEC 24759:2017 and as specified in

ISO/IEC 19790:2012 paragraph B.1.

NIST SP 800-140Cr2 replaces the approved security functions of ISO/IEC 19790:2012 Annex C. As a validation authority, the CMVP may supersede this Annex in its entirety. This document supersedes ISO/IEC 19790:2012 Annex C and ISO/IEC 24759:2017 paragraph 6.15.

NIST SP 800-140Dr2 replaces the approved sensitive parameter generation and establishment methods requirements of ISO/IEC 19790:2012 Annex D. As a validation authority, the CMVP may supersede this Annex in its entirety. This document supersedes ISO/IEC 19790:2012 Annex D and ISO/IEC 24759:2017 paragraph 6.16.

NIST SP 800-140E replaces the approved authentication mechanism requirements of ISO/IEC 19790:2012 Annex E. As a validation authority, the CMVP may supersede this Annex in its entirety with its own list of approved authentication mechanisms. This document supersedes ISO/IEC 19790:2012 Annex E and ISO/IEC 24759:2017 paragraph 6.17.

NIST SP 800-140F replaces the approved non-invasive attack mitigation test metric requirements of ISO/IEC 19790:2012 Annex F. As a validation authority, the CMVP may supersede this Annex in its entirety. This document supersedes ISO/IEC 19790:2012 Annex F and ISO/IEC 24759:2017 paragraph 6.18.

Responsible Positions: NIST CMVP and CCCS CMVP Program Managers.

1.7.5 Implementation Guidance and Request For Guidance

Implementation Guidance (IG) *and* Request For Guidance (RFG) is issued to provide clarification and guidance with respect to an assertion or group of assertions and requirements found in the documents listed above. Often, this guidance is issued to assist CSTLs and vendors to apply the requirements to a particular type of cryptographic module implementation or technology. This guidance is also issued based on responses by NIST and CCCS to questions posed by the CSTLs, vendors, and other interested parties. The IG and RFG posts are available on-line on the official website at https://csrc.nist.gov/Projects/cryptographic-module-validation-program/fips-140-3-ig-announcements.

Responsible Position: NIST CMVP and CCCS CMVP Program Managers.

1.7.6 Web Cryptik User Guide

This guide is available in the Help area of the Web Cryptik tool. It covers the use of FIPS 140-3 Web Cryptik. It is expected to be updated often as new functionality, edits, and program changes are introduced. The user guide may also identify where IG information requested should be included in the report and security policy. This guide also provides guidance on how to fill in some of the available fields (e.g., laboratory information, vendor information). The guides for various versions are also available at https://csrc.nist.gov/Projects/cryptographic-module-validation-program/sp-800-140-series-supplemental-information/sp800-140b, in the Process Support Applications section of the Module Package Creation tab.

Responsible Position: NIST CMVP and CCCS CMVP Program Managers.

1.7.7 CSTL Accreditation Standards

NIST laboratory accreditation standards applicable to the NVLAP accreditation of CSTLs are published on the NVLAP website at https://www.nist.gov/nvlap.

NIST laboratory accreditation standards relevant to the NVLAP accreditation of CSTLs are:

NIST Handbook 150 (2020), *NVLAP Procedures and General Requirements,*

NIST Handbook 150-17 (2022), *NVLAP Cryptographic and Security Testing,* Document

Links for these documents and associated Lab Bulletins are available at https://www.nist.gov/nvlap/publications-and-forms/nvlap-handbooks-and-lab-bulletins.

Responsible Position: Chief of NVLAP.

1.7.8 Page Links on the CMVP Website Main Page

The CMVP website contain several FIPS 140-3 pages pertinent to the program:

1. FAQs (https://csrc.nist.gov/Projects/cryptographic-module-validation-program/faqs) contains frequently asked questions and answers.
2. Publications (https://csrc.nist.gov/Projects/cryptographic-module-validation-program/publications) contains the CMVP publications.
3. Validated Modules (https://csrc.nist.gov/Projects/Cryptographic-Module-Validation-Program/Validated-Modules) contains a link to the search tool for finding a specific module or aspects of module validation. In addition, the page contains information describing categories (active, historical, and revoked) and explains the difference between a module that is a product and one that is a component. The Caveats sub-page describes the module validation caveats that may warn a user of specific stipulations, conditions, or limitations of a module, to assist in making a risk determination on its usage
4. Modules in Process (MIP) List (https://csrc.nist.gov/Projects/Cryptographic-Module-Validation-Program/Modules-In-Process/Modules-In-Process-List) lists the review status for each cryptographic module whose scenario type is FS (Full submission) or UPDT (Update). The list tracks the test report after it has been submitted to the CMVP through validation. For each submission, the status and the date it went into that state is listed. The date will also be updated for any new submission to the CMVP, even if the status remains the same. For additional information regarding a specific module, please contact the vendor.
5. Implementation Under Test (IUT) List (https://csrc.nist.gov/Projects/Cryptographic-Module-Validation-Program/Modules-In-Process/IUT-List) contains information provided by the CSTLs about cryptographic modules undergoing testing. The result of the testing has not yet been submitted to the CMVP. Inclusion of a module on this list is voluntary, dependent on the vendor. The CMVP has no information regarding the status of these modules and does not know if or when a test report will be submitted to the CMVP. The modules

are listed by vendor name. For more information regarding a specific module, please contact the vendor.

6. Entropy Validations

(https://csrc.nist.gov/Projects/cryptographic-module-validation-program/entropy-validations) This has a search page, announcements, and documents pertaining to the Entropy Validations.

7. Programmatic Transitions (https://csrc.nist.gov/Projects/cryptographic-module-validation-program/programmatic-transitions) lists algorithm-related transitions. Applicable standards, relevant IGs, ACVTS availability, and the beginning CMVP acceptance date are listed for each algorithm/scheme. Also available is information related to deprecated algorithms/schemes and whether they force validated module certificates to the historical category. Included in this list are deadlines for last submission date as an approved algorithm/scheme as well as the date whereby the validation certificate of an approved module using the algorithm/scheme will be moved to the Historical list.

8. CMVP FIPS 140-3 Management Manual (https://csrc.nist.gov/Projects/cryptographic-module-validation-program/cmvp-fips-140-3-management-manual) contains the link to the latest version of this manual.

9. CMVP FIPS 140-3 Related References (https://csrc.nist.gov/Projects/cryptographic-module-validation-program/fips-140-3-standards) describes the FIPS 140-3 standard, referenced standards in FIPS 140-3, and CMVP management documents.

10. FIPS 140-3 IG and RFG Announcements (https://csrc.nist.gov/Projects/cryptographic-module-validation-program/fips-140-3-ig-announcements) is where the latest version of the FIPS 140-3 IGs and RFGs can be found. The webpage also includes a short summary of IG changes.

11. SP 800-140 Series Supplemental Information (https://csrc.nist.gov/Projects/cryptographic-module-validation-program/sp-800-140-series-supplemental-information) contains a table summarizing the SP 800-140x series publications and their relationships to ISO/IEC 19790:2012(E) and ISO/IEC 24759:2017(E). The sub-pages of this webpage provide the supplemental information associated with that SP 800-140x document.

12. FIPS 140-3 Resources (https://csrc.nist.gov/Projects/cryptographic-module-validation-program/140-3-resources) provides guidance referenced in the FIPS 140-3 Management Manual. As an example, specifically detailed validation and re-validation information such as minimum testing requirements for revalidation and equivalency can be found here. TE Documentation Guidance is also available.

13. Use of FIPS 140-3 or FIPS 140-2 Logo and Phrases

(https://csrc.nist.gov/Projects/cryptographic-module-validation-program/use-of-fips-140-2-logo-and-phrases) References and information as to the proper use and registration of CMVP FIPS 140 validation logos.

14. CVP Certification Exam Information (https://csrc.nist.gov/Projects/cryptographic-module-validation-program/cvp-certification-exam-information) In order to be a certified tester for a CSTL, an individual must pass this exam.

15. NIST Cost Recovery Fees

(https://csrc.nist.gov/Projects/cryptographic-module-validation-program/nist-cost-recovery-fees) NIST fees paid by CSTL for validations depending on scenario.

16. CSTL Accreditation and Fees (https://csrc.nist.gov/Projects/Testing-Laboratories) contains a link to the name and location of every CSTL accredited to perform Cryptographic and Security Testing. The list also includes a point of contact for each CSTL.

17. CMVP Validation Process

(https://csrc.nist.gov/Projects/cryptographic-module-validation-program/nist-cost-recovery-fees) Process flow showing the interactions between the CSTL, the Vendor, and the CMVP throughout the validation process.

18. Archived Notices (https://csrc.nist.gov/Projects/Cryptographic-Module-Validation-Program/Notices) contains copies of statements published in the Federal Register, programmatic or policy updates or information not related to CMVP documents or test tools.

19. Validation Process Flow (https://csrc.nist.gov/Projects/cryptographic-module-validation-program/cmvp-flow) contains a diagram and description of the CMVP validation process. This page also speaks to validations that have undergone patches and CVEs and how that could impact the validation status, and the CMVP's recommendation.

Responsible Position: NIST CMVP and CCCS CMVP Program Managers.

2 CMVP Management

2.1 Introduction

The purpose of this section is to describe the overarching management structure and principles of the CMVP.

2.2 Validation Authority

The validation authority is the CMVP. The CMVP is jointly managed by NIST and CCCS. NIST and CCCS have both signed agreements for the management of the program that contains precepts by which both parties must abide. Copies of the agreements are kept by the Partnerships Group at CCCS and by the Computer Security Division at NIST.

2.3 Programmatic Directives, Policies, Internal Guidance and Documentation

The CMVP issues programmatic directives, policies, internal guidance, and documentation to all CSTLs. These communications are normally distributed by email. These communications are very important and can seriously impact on-going validation efforts. Information will be incorporated into the CMVP documentation over time.

The CMVP will strive not to make those directives and guidance retroactive to previous validations. However, the status of previous validations may be affected. CSTLs are encouraged to provide timely comments to the CMVP about those communications.

2.4 CMVP Points of Contact

Questions concerning the general operation of the CMVP can be directed to either NIST or CCCS. If a vendor is under contract with a CSTL for cryptographic module or algorithm testing, the vendor must contact the contracted CSTL for all questions concerning the test requirements.

The email address cmvp@nist.gov will be used for the general public to contact NIST CMVP and will continue to be published on the website as the main CMVP email account for NIST. The cmvp@cyber.gc.ca email address will continue to be separately supported and used by the CCCS CMVP office.

For general correspondence:

General Information Email Address	Purpose and Use
cmvp@cyber.gc.ca	All correspondence and FIPS 140-2 submissions to the CCCS CMVP.
cmvp@nist.gov	General correspondence to the NIST CMVP.

sp800-140-comments@nist.gov	Comments on CMVP guidance using the CMVP comment template.

The NIST CMVP uses some additional emails for specific CSTL communications, per below. Please only use the single email address required. PGP is used for encrypted email.

For CSTL use only	Purpose and Use
cmvplab@nist.gov	General correspondence to the NIST CMVP office that is not included below.
cmvpauto@nist.gov	For use in FIPS 140-2 module/report processing. For FIPS 140-3 submissions, no email address is used as Web Cryptik and Box have taken the place of this email.
cmvp-processing@nist.gov	For questions and errors related to processing module/report submissions.
cmvpitar@nist.gov	For use in FIPS 140-2 ITAR module/report processing. FIPS 140-3 ITAR communications will use this email address; however, for submissions, Box has taken the place of this email.

Note 1: In general, if you have been in direct email communication with a CMVP member then continue to email them.

Note 2: CSTL correspondence to cmvplab@nist.gov and general correspondence to cmvp@nist.gov should also be sent to cmvp@cyber.gc.ca unless the matter only relates to NIST or CCCS.

Note 3: We also strongly recommend that the group/shared email addresses (cmvplab@nist.gov and cmvp@cyber.gc.ca) not be put in the "CC" address line as a general rule to ensure that someone in the appropriate CMVP area will read and respond to the mail. Our respective offices will ensure that everyone who needs to be included will see the email.

The list of CMVP points of contact can also be found on the CMVP website at: https://csrc.nist.gov/projects/cryptographic-module-validation-program.

2.4.1 Language of Correspondence

All correspondence between NIST, CCCS, NVLAP, and the CSTLs must be in the English language only.

2.5 Request for Guidance from CMVP

The CMVP suggests reviewing the CMVP Management Manual, IGs, RFGs, the CMVP Announcements, and CMVP Notices posted on the CMVP websites first as answers to questions

may be readily available. The information found on the CMVP website provides the official position of the CMVP. If the information cannot be found in the aforementioned guidance, CMVP will accept request for guidance (RFG) from the CMVP that are general knowledge or to a specific application. In addition, CMVP will accept post-validation RFGs for any perceived issues relating to existing modules.

Vendors who are under contract with a CSTL for cryptographic module or algorithm testing of a specific implementation(s) must contact the contracted CSTL for any questions concerning the test requirements and how they affect the testing of the implementation(s).

Once a vendor is under contract with a CSTL, CMVP will only provide official guidance and clarification for the vendor's module through the point of contact at the CSTL. In a situation where the vendor and CSTL are at an irresolvable impasse over a testing issue, the vendor may submit an RFG directly to the CMVP. The point of contact at the CSTL must be included in the distribution of this correspondence. All correspondence from CMVP to the vendor on the issue will be issued through the CSTL point of contact.

All RFGs must be in the below Request for Guidance Format and be sent to both cmvplab@nist.gov and cmvp@cyber.gc.ca. Do not send the requests to individuals.

Federal agencies and departments, and vendors not under contract with a CSTL who have specific questions about cryptographic module testing requirements or any aspect of the CMVP should contact the appropriate NIST and CCCS points of contact. Questions can either be submitted by e-mail, telephone, or written (if electronic document, Microsoft Word document format is preferred).

CSTLs may submit test-specific or more general RFGs. All RFGs must be in the below Request for Guidance Format and be sent to both cmvplab@nist.gov and cmvp@cyber.gc.ca. Do not send the requests to individuals.

2.5.1 Request for Guidance Details

Requests must be aimed at clarifying issues about cryptographic module testing or other aspects of the CMVP and must be submitted to the CMVP written in the RFG format described below.

A response may require internal review by both NIST and CCCS, as well as with others as necessary, and may require follow-up questions from the CMVP. Therefore, such requests, while time-sensitive, may not be resolved immediately. If the CMVP has not sent feedback within a month, a follow-up status request is recommended.

CMVP replies to RFGs will state current policy or interpretations with every attempt made to be accurate, consistent, and clear, on a timely basis. However, these are non-binding and subject to change once the full report submission is received.

To increase collaboration, transparency, and consistency, the CMVP strongly recommends submitting RFGs that are NON-PROPRIETARY, so that the RFG and CMVP resolution can be made public to benefit the community (see FIPS 140-3 IG and RFG Announcements). The CMVP may leverage experts within the Cryptographic Module User Forum (CMUF) Working Group to help with the RFG recommended response. The CMVP will remove identifiable information if requested by the submitter.

The email will have the subject line "[ID]-FIPS140-3-RFG-[NAME]-yyMMdd-N" where ID is the two-digit CSTL code (if not applicable, enter NA), NAME is the submitters name (e.g., CSTL, vendor), yyMMdd is the year, month, and day of submission, and N is the number of RFGs with the same subject line sent on the same day (so they are each unique).

Example 1: NA-FIPS140-3-RFG-VendorA-230630-1
Example 2: 99-FIPS140-3-RFG-CSTL_A-230630-1
Example 3: 99-FIPS140-3-RFG-CSTL_A-230630-2

If an International Traffic in Arms Regulations (ITAR) RFG submission, email cmvpitar@nist.gov **only** using PGP encryption, and indicate it is "ITAR" appended to "RFG". E.g.: 99-FIPS140-3-RFG_ITAR-CSTL_A-230630-1.

2.5.2 Request for Guidance Format

For each RFG, the following template must be used in either Word or PDF (preferred) format:

https://csrc.nist.gov/csrc/media/Projects/cryptographic-module-validation-program/documents/fips%20140-3/RFG%20Template.docx

2.5.3 Post Validation Inquiries

Once a module is validated and posted on the NIST CMVP website, many parties review and scrutinize the merits of the validation. These parties may be potential procurers of the module, competitors, academics, or others. If a party performing a post-validation review believes that a conformance requirement has not been met and this was not determined during testing or subsequent validation review, the party may submit an inquiry to the CMVP for review.

An Official Request must be submitted to the CMVP in writing with a signature following the guidelines above. If the requestor represents an organization, the official request must be on the organization's letterhead. The assertions must be objective and not subjective. The module must be identified by reference to the validation certificate number(s). The specific technical details must be identified and the relationship to the specific FIPS 140 Derived Test Requirements assertions must be identified. The request must be non-proprietary and not prevent further distribution by the CMVP.

The CMVP will distribute the unmodified official request to the CSTL that performed the conformance testing of the identified module. The CSTL may choose to include the participation of the vendor of the identified module during its determination of the merits of the inquiry. Once the CSTL has completed its review, it will provide to the CMVP a response with a rationale on the technical validity regarding the merits of the official request.

The CSTL will state its position on its review of the official request regarding the module:

1. is without merit and the validation of the module is unchanged.
2. has merit and the validation of the module is affected. The CSTL will further state its recommendations regarding the impact to the validation.

The CMVP will review the CSTL's position and rationale supporting its conclusion. If the CMVP concurs that the official request is without merit, no further action is taken. If the CMVP

concurs that the official request has merit, a security risk assessment will be performed regarding the non-conformance issue. Please see Annex A for the flow diagram illustrating the assessment process.

2.6 Roles and Responsibilities of Program Participants

The various roles and responsibilities of the participants in the CMVP are illustrated in Figure 1 below.

Who	**Vendor**	**CSTL**	**CMVP**	**User**
Function	Designs & Produces	Tests for Conformance	Reviews & Approves	Specifies & Purchases
Output	Cryptographic Modules	Assessment Report	Validation List	Security with Assurance

Figure 1 - Roles, Responsibilities, and Output in the CMVP Process

2.6.1 Vendor

The role of the vendor is to design and produce cryptographic modules that comply with the requirements specified in the applicable ISO/IEC standards and NIST SPs. Among other functions, the vendor defines the boundary of the cryptographic module, determines its modes of operation and its associated services, and develops an entropy and algorithm strategy and provide the information for the non-proprietary security policy. The security policy generation information can be found in https://csrc.nist.gov/Projects/cryptographic-module-validation-program/sp-800-140-series-supplemental-information/sp800-140b. When a cryptographic module is ready for testing, the vendor submits the module and the associated documentation to the accredited CSTL of its choice.

After the cryptographic module has been validated, the vendor manages post module validation through either a new validation or a revalidation process submitted by a CSTL. Any change to the module that is not part of either a validation or revalidation will invalidate the module.

2.6.2 Cryptographic and Security Testing Laboratory

The role of the CSTL is to independently test the cryptographic module to the requirements defined for the FIPS 140-3 security level and embodiment, and to produce a written test report for the CMVP Validation Authorities based on its findings. The CSTL can conduct algorithmic testing and verify compliance with the algorithm standards (there may be additional requirements beyond what is CAVP-tested), review the cryptographic module's documentation and source code, and perform the required testing of the module in accordance with the TR, SP 800-140*x* and IG. All testing is performed or witnessed by a CVP tester. If a cryptographic module conforms to all the requirements of the standards, the CSTL submits a written report to the Validation Authority (CMVP). If a cryptographic module does not meet one (or more)

requirements, the CSTL may work with the vendor to resolve all discrepancies prior to submitting the validation package to the Validation Authority. The CSTL reports to the vendor any implementations do not meet the FIPS 140-3 testing requirements. CSTLs can not submit non-conformant modules to the CMVP for validation without penalties.

CSTLs must confirm that claimed approved algorithms and security functions are compliant with all requirements of their respective standards (Special Publications) when some 'shall' statements are not addressed by CAVP testing. If such compliance is not clearly demonstrated in the validation report, the CMVP may require the CSTL to fill in tables or answer related questions prior to validation. It is the CSTL's responsibility to ensure and demonstrate full compliance for approved cryptographic claims of the module, including requirements not covered by CAVP tests.

The following information is supplemental to the guidance provided by NVLAP, and further defines the separation of the design, consulting, and testing roles of the laboratories. The CMVP policy in this area is as follows:

1. A CSTL may not perform validation testing on a module for which the laboratory has:
    a. designed any part of the module,
    b. developed original documentation (e.g., design specifications) for any part of the module,
    c. built, coded, or implemented any part of the module, or
    d. any ownership or vested interest in the module.
2. Provided that a CSTL has met the above requirements, the laboratory may perform validation testing on modules produced by a company when:
    a. the laboratory has no ownership in the company,
    b. the laboratory has a completely separate management from the company, and
    c. business between the CSTL and the company is performed under contractual agreements, as done with other clients.
3. A CSTL may provide clarification of the *Security requirements for cryptographic modules*, the *Test requirements for cryptographic modules*, and other associated documents at any time during the life cycle of the module.
4. A CSTL may also create the Finite State Model (FSM), Security Policy, Entropy Assessment Report (EAR) for an Entropy Source Validation, entropy Public Use Document (PUD), Non-administrator guidance, and Administrator guidance, which are specified as vendor documentation in FIPS 140-3. These must be taken from existing vendor documentation for an existing cryptographic module (post-design and post-development) and consolidated or reformatted from the existing information (from multiple sources) into a set format. CMVP must be notified of this at the time of submission by providing the listing of the CSTL generated documents required in ISO 24759 TEB.01.01. The CSTL must be able to show a mapping from the consolidated or reformatted CSTL-created documentation back the original vendor source documentation. The mapping(s) must be maintained by the CSTL as part of the validation records. Source

code information is considered vendor-provided documentation and may be used in the CSTL-created documentation.

2.6.3 CMVP Validation Authorities

The CMVP Validation Authority is a joint effort of the National Institute of Standards and Technology for the Government of the United States of America and the Canadian Centre for Cyber Security for the Government of Canada.

The role of the Validation Authorities is to establish a program to validate the testing for every cryptographic module. The tests are performed, and results are documented in the submission package prepared by a CSTL and reviewed by the CMVP. If the cryptographic module is determined to be compliant, then the module is validated, a validation certificate is issued, and the module validation list (available on-line) is updated. During the review process, the Validation Authorities submit any questions they may have to the CSTL. The questions are typically technical in nature and are intended to ensure that the cryptographic module meets the requirements of the standard and that the information provided is accurate and complete. The CSTL may need to re-submit the validation submission along with supporting documentation such as a draft validation certificate, validation report, or security policy.

The CMVP participates, on behalf of NVLAP, in the CSTL accreditation process, which includes reviewing the management system, creating and administering the proficiency exam, performing the on-site assessment, and overseeing the artifact testing.

2.6.4 Validated Module User

The user verifies that a cryptographic module that they are considering procuring has been validated and meets their requirements. A listing of validated cryptographic modules is available from https://csrc.nist.gov/Projects/Cryptographic-Module-Validation-Program/Validated-Modules/Search. A non-proprietary security policy is posted on the list for each validated cryptographic module so that a potential user can determine if the validated cryptographic module provides cryptographic services and protection required for their particular application and threat environment.

The CMVP validates specific versions of a cryptographic module, and the user must verify that the version procured is, in fact, the validated version. The version numbers for a validated cryptographic module are specified on the CMVP website and in the latest Security Policy.

Users can also develop product or system specifications that include the requirements for FIPS 140-3 validated cryptographic modules. It is important to note that a cryptographic module may be a complete product or a component thereof. Therefore, understanding the boundary and interface of the validated cryptographic module will help in the determination of an adequate cryptographic product.

2.7 CMVP Meetings

The CMVP is jointly managed by NIST and CCCS. Decisions are made jointly by both organizations, and the NIST and CCCS Program Managers communicate regularly. While most

CMVP internal meetings focus on interactions with the CSTL, the CSTL Manager Meeting is focused on assessments and improvements of the CMVP program operations and management.

2.7.1 CSTL Manager Meetings

NIST and CCCS organize CSTL manager meetings (typically annually) to discuss issues relating to the CMVP, CAVP, and CSTLs. An agenda is created and distributed to the CSTLs before the meetings and presentation materials are distributed to the CSTLs for reference following the meetings. CSTL managers are welcomed to add any new agenda items at any time. Typically, the CSTL manager meetings are to minimally include the CSTL managers and the CMVP and CAVP Validation Authorities, however CSTL staff may be invited to attend, space permitting. It is mandatory for CSTLs to have at least one attendee at the CSTL manager meeting.

Usual discussion topics for CSTL manager meetings include the following:

- Status of the CMVP
- Changed or new CMVP processes and/or procedures
- Standards updates
- Laboratory accreditation process update news
- Implementation Guidance in development
- Status of the CAVP
- Test tool development
- Upcoming meetings and/or symposiums

When possible, CSTL manager meetings are collocated with the annual International Cryptographic Module Conference (ICMC) so that CMVP and CSTLs can also directly interact with the community at large.

2.7.2 CMUF participation

The Cryptographic Module User Forum (CMUF) (cmuf.org) was established in 2013 by module vendors, users, and CSTLs to provide a platform for practitioners in the community of UNCLASSIFIED Cryptographic Module (CM) and UNCLASSIFIED Cryptographic Algorithm (CA) Validation Programs (VP). The CMUF formed the annual ICMC which was held along with the CSTL manager meetings. CMVP participated in the Conference and found the ICMC to be an excellent way to communicate with the community at large.

In recent years, CMUF has asked CMVP to attend and present at the scheduled (e.g., monthly) meetings. In this way, CMVP has been able to communicate with both CSTLs and vendors to define the planning and goals more clearly, while accepting feedback from the community. It has also allowed CMVP to hear programmatic issues that vendors and CSTLs are experiencing or anticipating in which CMVP may not have adequate awareness. CMUF also hosts working groups composed of volunteers to address various topics related to the standards that need further development.

2.8 Confidentiality of Information

The protection of vendor proprietary information is paramount to the success and credibility of the CMVP and CAVP. Proper safeguards must be implemented by NIST, CCCS, and the CSTLs to protect against unauthorized disclosure of vendors' proprietary information. Any potential or actual breach of confidentiality could have an adverse effect on the NIST, CCCS, a CSTL's accreditation, or the program.

As required by the CSTL accreditation standards listed in Section 3.1 of this manual, CSTLs are required to establish and implement procedures for protecting the integrity and confidentiality of data entry or collection, data storage, data transmission and data processing. CSTLs must protect cryptographic module validation test reports, and any proprietary information when these documents are submitted to NIST and/or CCCS outside of Web Cryptik / Box.

NIST, CCCS, and the CSTLs must ensure that personnel joining or departing these organizations are advised of their responsibilities about safeguarding the vendor proprietary information they may have been authorized to access during their period of employment.

3 CSTL Processes

This section describes administrative processes affecting CSTLs, including the granting and maintenance of accreditation, confidentiality of information, code of ethics, management of test data, and documentation.

3.1 Accreditation of CMVP scopes for CSTLs

This section describes in general terms the process for a laboratory to become an accredited CSTL for scope 17CM under the National Voluntary Laboratory Accreditation Program (NVLAP). Candidate laboratories may optionally apply for NVLAP 17CM-NI at the same time. 17ESV is also supported by CMVP, though is considered a separate program. Laboratories are responsible for complying with the Cryptographic and Security Testing LAP which can be found at https://www.nist.gov/nvlap/cryptographic-and-security-testing-lap.

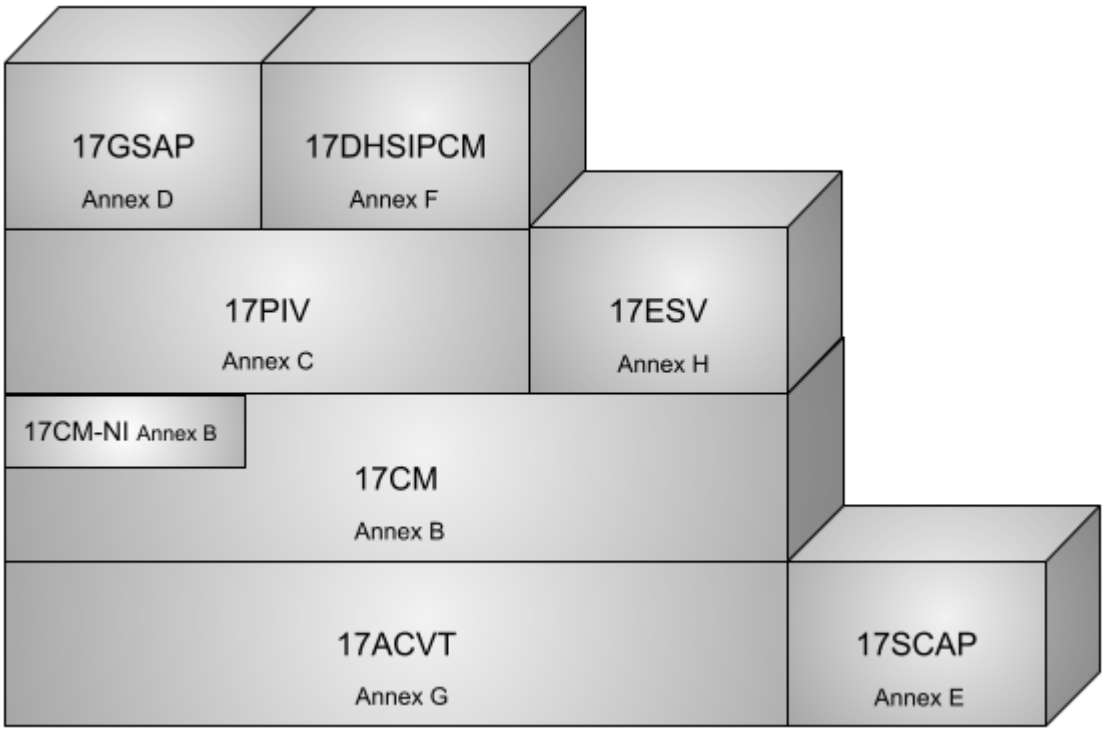


Figure 2 - CSTL NVLAP scopes

NOTE: Accreditation of the CAVP scope is necessary to obtain the 17CM scope for CMVP testing laboratories. For more information about CAVP accreditation, please see **Becoming a 17ACVT Laboratory** on the CAVP website https://csrc.nist.gov/Projects/cryptographic-algorithm-validation-program/how-to-access-acvts.

3.1.1 Accreditation Process for the CMVP scope

Applicant laboratories must complete the 17CM scope accreditation process within one year of

submitting the NVLAP application. Applications that are not completed within one year will have to be re-submitted, and the process will have to start again from the beginning. If the content of the accreditation process contained herein diverges from the aforementioned standards documents, those documents have precedence.

The accreditation process is illustrated in Figure 3. All steps in the accreditation process must be completed in the order shown.

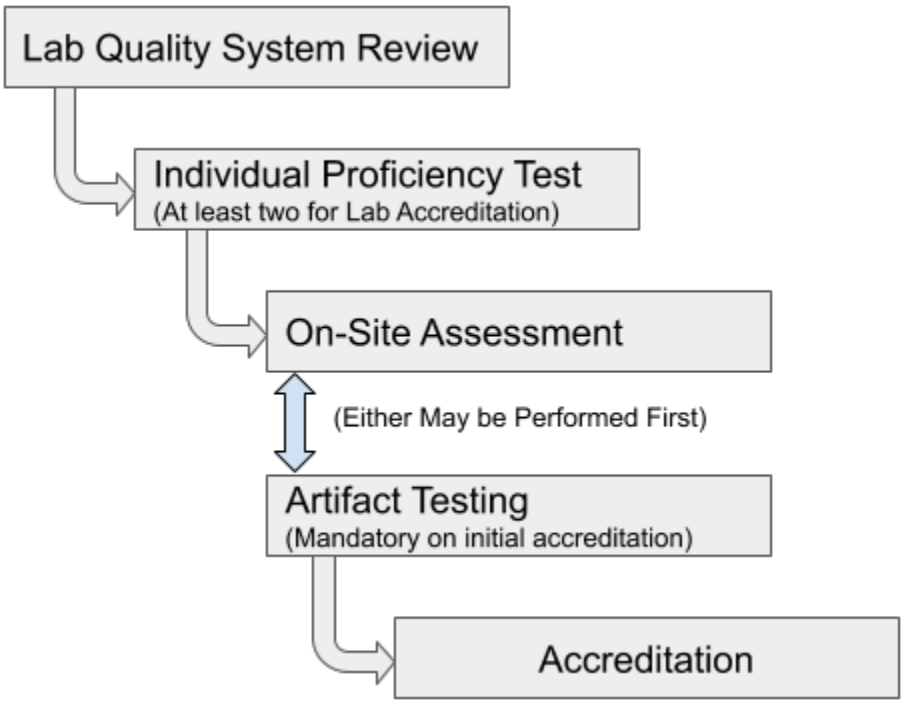


Figure 3 - CSTL Accreditation Process

3.1.1.1 Application for Accreditation and Selection of Assessment Team

The prospective CSTL must complete an application form, pay the respective fees, agree to the conditions of accreditation, and provide their quality system to NVLAP prior to the on-site assessment. Upon notification by NVLAP of an acceptable application, an assessment team is selected. This team is typically comprised of one or more technical assessors representing CMVP and one lead assessor from NVLAP. NVLAP technical assessors for CSTLs are selected by the NVLAP Program Manager and are chosen based upon their knowledge of the relevant FIPS standards and related documentation, NVLAP requirements, assessment techniques, and quality systems. The assessors must not have a conflict of interest with the CSTL they will be assessing.

3.1.1.2 Management System Evaluation

The assessment team will review the Management System to determine if it meets the requirements of NIST Handbook 150 and NIST Handbook 150-17.

3.1.1.3 CVP Proficiency Examination

Every independent tester, technical reviewer and submission signatory must maintain Cryptographic Validation Program (CVP) certification by passing the current proficiency exam.

The current written examination consists of approximately one hundred questions relating to various aspects of CSTL activities, FIPS 140-3, and cryptographic algorithm implementation testing. The exam is an individual certification exam. The certification exam will encompass the domains listed below:

a. Physical Security
    - Understand the different module types and different embodiments for modules.
    - Understand requirements for physical security for modules specific to levels 1-4.

b. Authentication, Roles, Services, Software/Firmware Security and Operational Environment
    - Understand authentication requirements and concepts.
    - Define the requirements for roles.
    - Understand the concepts of services using approved and non-approved functions, and the bypass capability.
    - Understand the self-initiated cryptographic output capability, Software/Firmware security including loading requirements and their applicability.
    - Describe the operational environment requirements/concepts and how to test them.

c. Algorithms and Self-Tests
    - Understand the concepts of the approved and allowed algorithms.
    - Identify which algorithms are approved or allowed.
    - Identify testing for components of the algorithms.
    - Identify the tester's responsibilities when reviewing an algorithm's implementation.
    - Identify the pre-operational self-tests (e.g., integrity, bypass) and know the associated requirements.
    - Understand the requirements for conditional self-tests, including cryptographic algorithm self-tests.

d. Sensitive Security Parameter (SSP) Establishment
    - Understand the requirements for SSP generation, SSP agreement, SSP transport and SSP derivation and applicable standards and guidance.
    - Understand and identify the approved random bit generators.
    - Understand the notion of entropy and methods of entropy estimation.
    - Possess general knowledge of the SSP establishment protocols and standards in the IT industry.

e. SSP Management
    - Understand the requirements for SSP entry and output and trusted channels.
    - Understand the requirements for SSP storage.
    - Understand the various types of SSPs and their zeroization requirements.

f. Security Assurances
    - Understand the requirements of module specification including degraded operation, approved and non-approved modes.
    - Understand the programmatic guidance and associated documentation requirements.
    - Understand the requirements for ports & interfaces, finite state model, development, mitigation of non-invasive and other attacks, and design assurance.

The exam is graded, and the results are recorded by the CMVP and provided to the exam taker. CMVP provides an exam score if passed; otherwise, the scoring for each area not passed is provided. Scoring is adjusted for the difficulty of the exam taken, but transparent to the exam taker. An opportunity is provided for retaking the exam in the event of failure. Once passed, the reexamination period for maintaining the certification for CVP certified testers is four years. In the event of major program updates, e.g., a new FIPS 140 standard, the reexamination frequency may be increased to encompass changes in the technical requirements. For the most up to date information, refer to the CVP Certification Exam Information tab (https://csrc.nist.gov/Projects/cryptographic-module-validation-program/cvp-certification-exam-information) on the CMVP website.

3.1.1.4 On-Site Assessment

An on-site assessment of the laboratory is conducted to determine compliance with the accreditation criteria. The on-site assessment is scheduled by the assessment team following receipt of payment and a passing grade on the CST Proficiency Examination by a minimum of two CST testers. An assessment typically takes two to three business days to perform. The activities performed during an assessment are described in Section 3.3 of NIST Handbook 150.

For an **accredited** CSTL, any deficiencies found during the assessment, the laboratory must submit a satisfactory plan concerning resolution of deficiencies to NVLAP within thirty days of notification. If the plan for correcting deficiencies is not submitted within 30 days, the CSTL may be suspended for the applicable scopes.

For an **applicant** CSTL, any deficiencies must be addressed by a satisfactory plan within thirty days of notification and resolved before being eligible for accreditation.

3.1.1.5 Artifact Testing

After two testers pass the CVP exam or following the on-site assessment, the assessment team may provide an artifact that the applicant laboratory must test and submit according to the requirements and policies of the CMVP. The CMVP will then assess the competency of the laboratory using the responses provided in the test report. The initial NVLAP application process includes the testing of the artifact, all of which must be completed within one (1) year.

3.1.1.6 Accreditation Decision

The CMVP will make a recommendation of the applicant laboratory competency. NVLAP will evaluate the results of the laboratory assessment and the CMVP recommendation, before making the final accreditation decision.

3.1.1.7 Granting Accreditation

If approval has been granted to accredit the CSTL for Cryptographic Security testing, NVLAP will assign the CSTL one of four renewal dates for the beginning of operation:

g. January 1
h. April 1
i. July 1
j. October 1

The accreditation period is one year. After initial accreditation, NVLAP will conduct an on-site assessment after completing the first year of accreditation and then every two years thereafter (see NIST HB 150, 3.2.3.3). The CSTL receives an NVLAP certificate and scope of accreditation identifying the CSTL address, lab code, the CSTL's authorized representative, and the expiration date of the accreditation.

3.1.1.8 CMVP Test Tools

Once accreditation has been granted and the CMVP is advised by NVLAP that the applicant laboratory has been accredited, the CMVP will issue to the newly accredited CSTL access to the latest version of Web Cryptik and associated tools. CMVP will also issue the latest programmatic directives and policies, and internal guidance and documentation. The CSTL is also required to have secure email capability using PGP for CUI communications unless submitted through Web Cryptik. The lab is limited to two PGP email addresses in which to communicate with the CMVP, of which one may be a shared email address within the CSTL. PGP is not provided by the CMVP.

3.1.1.9 Cooperative Research and Development Agreement

All accredited CSTLs must execute a Cooperative Research and Development Agreement (CRADA) agreement with NIST in order to do business with the CMVP. The agreement covers the protection of information as well as the fees being charged by NIST for each type of CMVP test report submission (scenario). This agreement is effective through October 31, 2026, with amendments as required. New laboratories are required to execute the agreement once they become accredited through NVLAP. Existing laboratories must re-execute the agreement upon change or expiration. The NIST CMVP Program Manager is the point of contact for obtaining a copy of the current CRADA.

3.2 Maintenance of CSTL Accreditation

3.2.1 Proficiency of CSTL

There is no requirement for a test report submission during the first year of accreditation. For all successive years of accreditation, the following requirements apply. An accredited CST laboratory must submit a minimum of two (2) test reports annually (every 12 calendar months) to

the validation authority to demonstrate continued testing proficiency.

This permits the CMVP staff to monitor the quality of the CSTL processes, the technical skills, and knowledge of the CSTL staff. Failing this, NVLAP may suspend or revoke the CSTL's accreditation.

In addition, laboratories are also required to have a minimum of two CVP FIPS 140 Certified Testers throughout the accreditation period.

3.2.2 Renewal of Accreditation

Each accredited CSTL will receive a renewal application package before the expiration date of its accreditation to complete the renewal process. Fees for renewal are charged in accordance with the fee schedule published on the NVLAP website at https://www.nist.gov/nvlap/nvlap-fee-structure. Both the application and fees must be received by the accreditation body prior to the expiration of the CSTL's current accreditation to avoid a lapse in accreditation.

The re-accreditation process is the same as illustrated in Figure 3 - CSTL Accreditation Process and described in Section 3.1.1 above. If deficiencies are found during the assessment of an accredited CSTL, the laboratory must submit to NVLAP a satisfactory plan outlining the resolution of deficiencies within thirty days of notification. On-site assessments of accredited laboratories are performed in accordance with the procedures in Section 3.3 of NIST Handbook 150.

3.2.3 Ownership of a CSTL

In the event a CSTL changes ownership, the accreditation body and the CMVP Validation Authorities must be informed within ten (10) working days of the effective date of the change. The CSTL must also submit an updated Quality System to NVLAP showing the new owner information.

3.2.4 Relocation of a CSTL

In the event a CSTL relocates to a new facility, the laboratory director must submit a relocation plan to the accreditation body and the CMVP at least one month before the relocation. The relocation plan must demonstrate that the new location meets the requirements as set out in the accreditation standards including information protection. The plan must also describe how sensitive information will be moved between locations. The accreditation body and the CMVP staff may conduct a monitoring visit after the relocation is completed to ensure all accreditation requirements continue to be met. In addition, it should be noted that a change of location may result in a change in customer ID for NIST billing.

3.2.5 Change of Approved Signatories

In the event of a change of the CSTL's Approved Signatories, the accreditation body and the CMVP must be informed within thirty (30) working days of the new signatories and the effective date of the change. All approved signatories must have passed the CVP exam prior to signing a validation submission.

3.2.6 Change of Key Laboratory Testing Staff

Key personnel include:

a. laboratory director;
b. laboratory manager(s);
c. staff members(s) responsible for maintaining management system;
d. authorized representative;
e. approved signatories; and
f. other key technical persons in the laboratory (e.g., testers).

In the event of changes to key laboratory testing staff, the accreditation body and the CMVP must be informed of the new staff and the effective date of the change within thirty (30) working days. Failure to communicate laboratory staff changes to the accreditation body and the CMVP may result in an adverse action regarding accreditation. The laboratory must submit an updated organizational chart to NVLAP and the CMVP noting any changes.

3.2.7 Monitoring Visits

Monitoring visits may be conducted by the accreditation body at any time during the accreditation period, for cause or on a random basis. While most monitoring visits will be scheduled in advance with the CSTL, the accreditation body may conduct unannounced monitoring visits. The scope of the monitoring visits may range from an informal check of specific designated items to a complete review.

3.2.8 Extended Cost Recovery

Extended Cost Recovery (ECR) fees and points may apply when a submission results in one of the following categories:

Points	Category	Examples
0	Excessive CMVP time (non-errors)	1. Excessive number of modules in one report. 2. Excessive submission size and/or complexity. 3. Special exception requests which require significant or specialized effort by CMVP. 4. Submitting RFGs on topics for which guidance has already been published, or not submitting an RFG in advance that results in significant effort to address during Coordination. 5. The module represents a new technology, a new type of fabrication, a unique implementation, or an unusual level of complexity and/or many functions and services.
1	Basic process errors	1. Not following the CMVP submission process (e.g., not sending to the proper email address or account, TID duplication, improper use of encryption, missing required documentation,

		incomplete and/or inconsistent procedural/administrative documents).
2-3	Significant quality errors	1. Submissions generate excessive comments or excessive non-productive comment rounds. 2. Incomplete technical documentation leaving open technical questions, due to missing, incomplete, or inconsistent technical claims. 3. Not addressing or following CMVP Implementation Guidance or other CMVP guidance. 4. Significant documentation issues that have a security impact (see section 4.7 'd' for examples). 5. Making unidentified changes to the module and/or documentation during Coordination or as part of a revalidation.
4	Severe submission process errors or process misuse	1. Exposing or mishandling sensitive information such as bypassing protections. 2. A submission that is used as a placeholder, i.e., the report was not the intended version to be validated and/or was knowingly incorrect or incomplete.
5	Security non-conformance or inaccurate representation of a module	1. Discovery of a security non-compliance or security flaw in a cryptographic module (typically one that would require module code changes to correct). 2. Purposely using incorrect information that misrepresents the module or its security features.

General ECR guidance:

1. Any of the above can apply to both module and ESV validations.
2. Depending on the issues identified, ECR may apply in cases where, post validation, a validated module is identified in the Flaw Discovery Handling Process and found to be incorrect.
3. Repeat ECR offenses may result in additional points (not to exceed 5 points) applied compared to what is listed in the table above.
4. The above ECR examples (non-exhaustive) may apply when clear CMVP guidance exists that was not followed.

An accredited laboratory must maintain an Extended Cost Recovery (ECR) point total of less than 12 points. If a CSTL accumulates 12 or more points during the prior two (2) years, the CMVP will recommend to NVLAP that the accreditation for the cryptographic module testing be suspended.

If a CSTL has reached 6 or more points through the ECR process, the CMVP recommends the following actions to pre-empt suspension:

The lab compiles a list of all reports in the Pending Review state in the CMVP queue. Per policy, those reports are eligible for resubmission. If the CSTL elects to

review those submissions for potential resubmission, the CMVP may initiate up to a 30-day HOLD to allow the CSTL time to make any corrections needed prior to the reports moving to the Review state. The CMVP would need to be notified in writing regarding which reports, if any, the CSTL would like to put on HOLD pending a resubmission. The final determination will be up to the CMVP.

3.2.9 Suspension of Accreditation

If NVLAP becomes aware that an accredited laboratory has violated the terms of accreditation, NVLAP may suspend the CSTL's accreditation. The determination by NVLAP whether to suspend the CSTL will depend on the nature of the violation(s). A letter from NVLAP will include a request for a remediation plan and an on-site review and artifact testing if needed. CSTLs must be in compliance with the NVLAP requirements prior to lifting the suspension.

Four areas of non-conformities that will lead to suspension of accreditation as stated in Handbook 150-17:

1. reports submitted for validation within the accreditation cycle are incorrect, invalid, or deficient as defined by each validation program (see 3.2.8);
2. the loss of key technical personnel from the CSTL;
3. nonconformities found during any onsite visit are not appropriately addressed through corrective actions taken by the CSTL; or
4. the CSTL has not submitted the required number of vendor product test reports to the validation authority within the accreditation cycle.

3.2.10 Revocation of Scope

If correcting the non-conformities is too onerous for the CSTL, the laboratory may elect to have NVLAP revoke the accreditation. A CSTL may at any time terminate its participation and responsibilities as an accredited laboratory by advising NVLAP and the CMVP in writing of its intent. Upon receipt of a request for termination, NVLAP must begin the termination process by notifying the CSTL that its accreditation has been terminated. The CSTL will be instructed to return its Certificate and Scope of Accreditation and to remove the accreditation body's logos from all test reports, correspondence, and advertising. Finally, the laboratory must return or provide signed confirmation of the destruction of all CMVP and CAVP provided material, test tools, and documentation. The CMVP will determine the course of action taken for any outstanding work that has not been completed. This will be handled on a case-by-case basis.

3.3 Confidentiality of Proprietary Information

Maintaining confidentiality of proprietary information is paramount to the operation of CMVP and requires the establishment and enforcement of appropriate controls.

3.3.1 Confidentiality of Proprietary Information Exchanged between NIST, CCCS and the CSTL

The confidentiality of the proprietary information exchanged between NIST, CCCS, and the CSTL is required by NVLAP at all times during and following the testing. All proprietary

materials must be marked as PROPRIETARY by the CSTL or the vendor.

3.3.2 Non-Disclosure Agreement for Current and Former Employees

The CSTL must develop and maintain non-disclosure agreements for staff that participate in the testing of modules.

3.4 Code of Ethics for the CSTLs

The CSTL must:

1) Maintain NVLAP accreditation for the Cryptographic Security Testing Program;
2) Refrain from misrepresenting the scope of its accreditation;
3) Act legally and honestly;
4) Act ethically.

3.5 Management of CMVP and CAVP Test Tools

Test tools provided by NIST and CCCS must not be distributed to any entity outside the CSTL, including firms contracted by the CSTL, unless explicitly authorized by CMVP management. Personnel temporarily employed by and working under the supervision of a CSTL (i.e., a contractor) can use the provided test tools when they are used within the CSTL facilities. Test tools include all versions of Web Cryptik, the Automated Cryptographic Validation Testing System (ACVTS), and any other tools provided by NIST and CCCS for use by the CMVP and CAVP. Violation of this policy may be considered cause for suspension of the CSTL's accreditation.

4 CMVP Processes

This section describes cryptographic module validation processes, including an overview of the program and the steps required to attain and maintain validation.

4.1 Cryptographic Module Validation Process Overview

This section provides a high-level overview of the validation program, primarily focused on the CSTL and CMVP interaction, followed by the vendor and laboratory interaction. The remaining subparagraphs work through the process performed by the vendor, CSTL, and CMVP for any submission, including full submissions and resubmissions. Figure 4 shows the general flow of testing and validation of a cryptographic module.

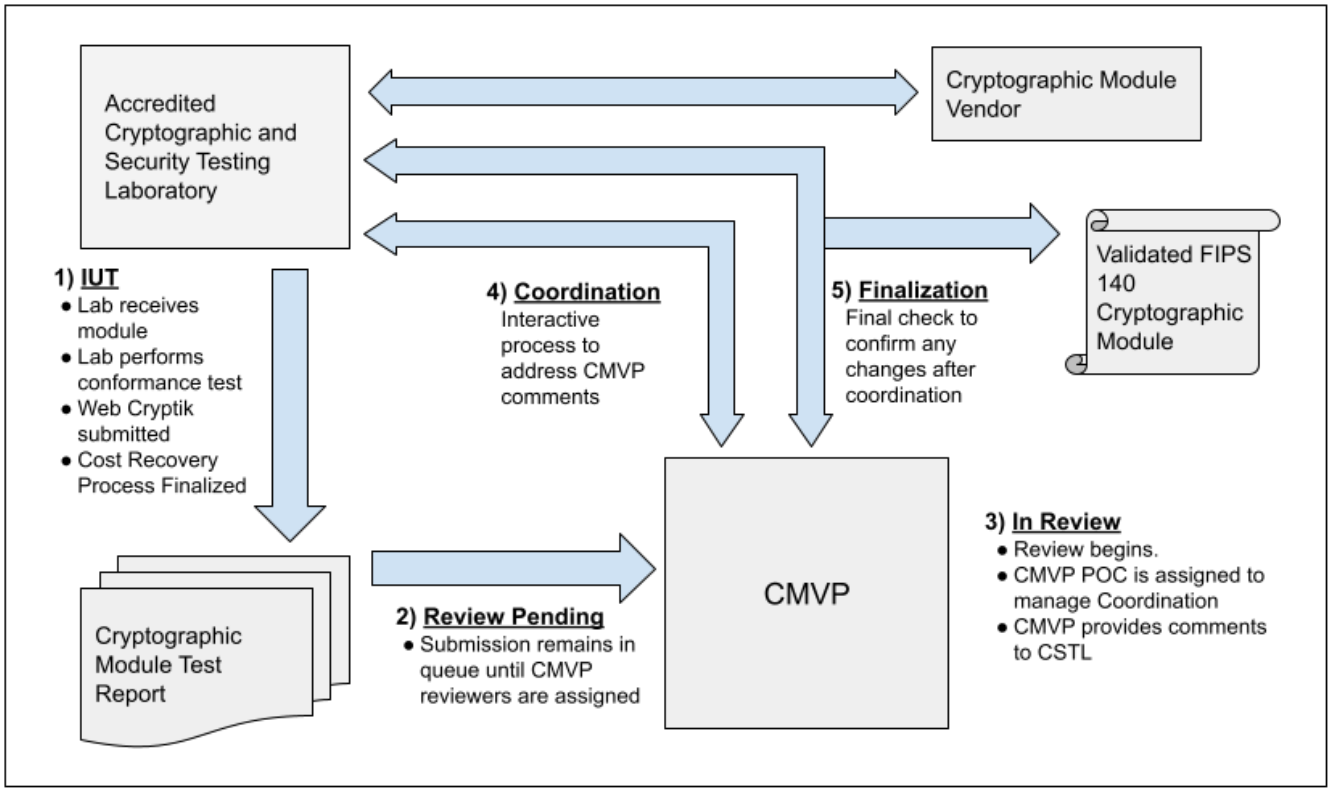


Figure 4- Cryptographic Module Testing and Validation Process

4.1.1 Vendor, CSTL, and CMVP duties for Testing of the Cryptographic Module

A vendor contracts with an accredited CSTL to perform the cryptographic module validation testing. The vendor provides the CSTL with the necessary documentation and either provides the cryptographic module to the laboratory for testing or prepares it for testing at the vendor's facility.

To communicate specific validation information to CMVP, the CSTL must assign a Tracking Identification Number (TID). Once the laboratory is accredited, the CMVP assigns the first two digits of the TID; the second set of four digits is assigned by the CSTL and must be unique to the

validation. Validation-related submissions to CMVP should follow the instructions provided in the Web Cryptik User Guide.

4.1.1.1 Implementation Under Test

Once vendor's contract has been executed and the vendor documentation is delivered to the CSTL, the cryptographic module can begin testing. The CSTL may optionally notify CMVP that the cryptographic module is to be included on the IUT List by providing the name of the cryptographic module; the cryptographic module vendor's name. Inclusion in the IUT list is voluntary. The module information on the IUT List will be removed after 18 months. The CSTL will be notified when the IUT entry is dropped.

The CSTL performs the cryptographic module testing as prescribed by the ISO/IEC 24759:2017 *Test Requirements* (TR), the SP 800-140 series, and all applicable IGs. The testing information is entered in the Web Cryptik tool. Although testing requirements are in the ISO/IEC 24759:2017 TR, ISO/IEC 19790:2012, *Security Requirements for Cryptographic Modules* remains the definitive reference for whether or not the cryptographic module meets the requirements of the standard. Any deviation from the *test requirements* that meet the *security requirements* needs to be approved by CMVP prior to submission.

The cryptographic module validation process is an iterative process. At any point in the testing the CSTL may wish to request guidance from CCCS and NIST in determining how to apply the FIPS 140 standard to the particular cryptographic module. If the CSTL discovers any non-conformances in the cryptographic module documentation or the cryptographic module itself, it must bring details of the non-conformance(s) to the attention of the cryptographic module vendor. The cryptographic module vendor must correct the non-conformance(s) and resubmit updated documentation and the updated cryptographic module as necessary for validation testing.

Once the CSTL completes all required cryptographic algorithm and entropy source validations along with module testing, the CSTL can determine that the cryptographic module is conformant to FIPS 140-3. The CSTL then prepares the submission using Web Cryptik. The CSTL addresses each TE independently, not by referencing a response in another TE.

See the Web Cryptik User Guide for a summary table that describes what must be submitted by the CSTL for validation. Web Cryptik aids the CSTL in preparing submissions, please refer to the Web Cryptik User Guide and the SP 800-140B Supplemental Information webpage for additional information.

4.1.1.2 Cost Recovery, Pending Resubmission and Pending Review

All FIPS 140 validation submissions received by the NIST and CCCS CMVP. If the initial examination reveals issues, the CSTL is notified, and the submission is not accepted for review. When the submission is accepted by the CMVP and COST RECOVERY is completed (see Cost Recovery Program (CR & ECR)) the module is moved from the Cost Recovery state (if applicable) of the MIP List to either the PENDING RESUBMISSION state (if there are triage comments per below) or the PENDING REVIEW state (if there are no triage comments). Pending Review transitions to Review once the first CMVP reviewer begins the review.

At the CMVP's discretion, a test report in this state may be subject to a triage review to quickly assess the quality of a report, and if needed, provide feedback to the lab. This triage activity is

implemented based on high-level and common issues observed from the submissions received by the CMVP. Ability to quickly identify and address problematic submissions is paramount to not only advance the FIPS 140-3 queue, but also be fair to all labs and vendors. Problematic submissions will be sent back to the labs accompanied by generic statements for resolution. These reports *will* maintain their respective queue positions.

During periods when the CMVP submission queue is long, CSTLs are encouraged to submit updated submissions to minimize any follow-on revalidations that might be necessary (see Section 4.3.5 *Resubmission while in Pending Review*).

4.1.1.3 Review

After the CMVP reviewers have been assigned to the submission, and the reviewer begins the review, the cryptographic module is moved to the REVIEW state of the MIP List. The module validation must be completed and cannot exceed 24 months after transitioning to REVIEW, or they will be subject to being dropped and would have to begin the process from the start. Once they have completed their review of the validation submission and provided comments, a comment file is sent to the CSTL. This event moves the cryptographic module to the COORDINATION state, described below.

4.1.1.4 Coordination (Comment Resolution)

After receiving the comments from the CMVP, the module moves to the Coordination phase (described as Comment Resolution – Lab on the MIP List). After conferring with the vendor, as necessary, the CSTL addresses the comments and resubmits a complete submission package containing any modified documents to the CMVP (described as Comment Resolution – CMVP on the MIP List). The CMVP reviewers examine the responses and respond with any additional comments, if necessary. Additional rounds may result in a NIST ECR Fee and possible points (see section 3.2.8 *Extended Cost Recovery*). This process continues until the CSTL receives an All OK from the CMVP. Each round of comments will result in an update in the MIP List date. The CSTL must respond within 90 days to prevent the review from being placed on Hold (see HOLD Status for Cryptographic Modules on the Modules In Process). Also, see Section 4.3.6 *Changes while in Coordination* for more information.

4.1.1.5 Finalization

The FINALIZATION state focuses on assuring any changes during the Coordination phase have been updated by the CSTL and confirm the vendor and module information is accurate. If any changes are necessary, another finalization review will be performed. With the successful completion of the submission review, the validation is posted on the CMVP website.

4.1.1.6 Validation Certificate

Once the information is confirmed, the Validation Authorities, issue a certificate number which is added to the database. The web-based search tool for the database can be found at https://csrc.nist.gov/Projects/cryptographic-module-validation-program/validated-modules/Search. The entry includes the version number of the validated cryptographic module and the benchmark configuration of the original validation testing.

The information on the certificate pertains to the module from the time of its validation. During the validation life cycle, information for that validation may change. For revalidations that do not create a separate validation number, the module's validation will be updated on the website and

the dates of the updates and the CSTLs that submitted the updates are appended to the entry. Therefore, users should refer to the NIST website for the latest information concerning a validation. A Consolidated Validation Certificate (CVC) is generated at the end of each month which lists all of the certificates that were published during the month. CCCS and NIST sign the CVC listing and it is posted as a link on each of the individual module validation entries.

4.2 Implementation Under Test (IUT) and Modules in Process (MIP)

The *CMVP Implementation Under Test (IUT) and Modules In Process (MIP) Lists* are provided for information purposes only. Participation on the lists is *voluntary* and is a decision made by the vendor. Modules are displayed alphabetically by name, but the list doesn't necessarily include all modules being tested or reviewed.

The IUT List is a way to identify modules that are currently under contract to be tested by a CSTL. The List provides the module name, vendor name, FIPS 140 standard, and the date of the last update.

The Modules In Process (MIP) List only includes scenarios that result in issuing a new certificate (i.e., Full Submission (FS), Update (UPDT), Rebrand (RBND), Port Sub Chip (PTSC), Algorithm Transition (TRNS)). The status of these submissions can be tracked through the MIP List. The List includes the module name, vendor name (and expandable contact information), FIPS 140 standard, current MIP state, and the date of the last MIP state change. Any module that the vendor does not choose to be made public will be reflected at the end of the list in the "Not Displayed" row without any identifying information.

The IUT and MIP Lists are explained and accessible on the NIST webpage https://csrc.nist.gov/Projects/cryptographic-module-validation-program/modules-in-process.

Note: Posting on either list does not imply or guarantee FIPS 140 validation.

4.3 Validation Submission Queue Processing

4.3.1 Full and Update Submission Validations

Modules submitted for initial validation (FS) and those submitted with less than 30% security changes (UPDT) will be queued together and addressed on a first-come, first-serve basis. All submissions in this queue must meet all requirements as of the submission date. The internal review disposition of a module report is left to the sole discretion of the NIST and CCCS CMVP program managers. Vendors should contact their CSTL for additional queue status.

In cases whereby submissions are related to or dependent on other submissions, e.g., bound or embedded modules, the CMVP must be notified for consideration prior to their submission. CSTLs should also include this information in the special instructions field in Web Cryptik. This will allow CMVP to manage resources in support of these larger efforts. In general, and for dependent or related modules, testing must be completed prior to submission (including FIPS 140-3 compliance testing and CAVP/ESV validations). In addition, prior to completion, the CSTL must review and address all changes from the completed validation.

4.3.2 All other submissions

The CMVP internally maintains separate queue(s) to maximize throughputs for all other submissions, which are expected to require less review effort and faster turnaround.

4.3.3 Request for Transition Period Extension

Some Implementation Guidance is assigned a transition period before compliance to this guidance is required; e.g., since meeting the guidance may require changes to cryptographic modules or the functional testing of them as opposed to documentation changes. In rare circumstances, the transition period may not be long enough for the vendor to perform the modifications needed to the cryptographic module for it to be compliant with the issued Implementation Guidance nor complete the additional cryptographic algorithm validation testing before the scheduled date for submission of the validation report.

These situations will be reviewed on a case-by-case basis at the request of the CSTL performing the validation testing. A ruling will be made by the CMVP as to whether an extension can be granted for this particular requirement, for this particular cryptographic module, depending on the type of cryptographic module and the status of the validation testing.

4.3.4 HOLD Status for Cryptographic Modules on the Modules In Process

While a CSTL may request a HOLD, the status can be executed by the CMVP. There are several reasons that a submission review may be placed on HOLD status. Some of these reasons are as follows:

1. If a module test report is sent incomplete or is determined to be incomplete once the module has moved to the REVIEW or a later state.
2. When the ECR notification is sent to the CSTL, the module will be placed on HOLD. If the ECR has been paid and the CSTL resubmits the report, the HOLD is removed.
3. If a non-compliance is discovered during the module review or coordination.
4. If a module is dependent on the completion of another module (i.e., the case of bound/embedding), the dependent module may be placed on HOLD until the base validation has been completed. The CSTL must indicate the module dependency upon submission via Web Cryptik Special Instructions. If a submission is put on HOLD due to dependency, it is the responsibility of the CSTL to notify the CMVP when the initial submission is completed. This assures the CMVP will remove the hold for related or dependent submissions.
5. During COORDINATION, CMVP comments are sent to the CSTL and if the CSTL has not responded within 90 calendar days, the module will be placed on HOLD. After 150 calendar days, an email notification will be sent to indicate that if no submission is received in the next 30 calendar days (180 calendar days in total), the module will be dropped from the CMVP queue. The CSTL must inform the vendor of the CMVP's intent to drop the module due to the 6-month period of delay. If the CSTL cannot respond to the CMVP Coordination comments within the allotted timeframe, the CSTL

must send an email justification to the CMVP identifying the reason for this delay at least two weeks prior to the drop date. The CSTL must include a timeline specifying the expected submission date for the CMVP's consideration. If no justification is received, the module will be dropped. A new submission could be sent once this module has been dropped but this would be a new submission and cost recovery would be applicable.

6. A CSTL has been placed in a suspension status by NVLAP. Work in progress may be placed in a HOLD until the suspension is lifted. No new work is allowed to be submitted during a period of suspension.

A module on HOLD will be reflected on the MIP List as "Hold" with the date of status change. Once the HOLD is lifted, the MIP entry will return to its prior state and queue position. If an ECR is applicable, the ECR must be resolved, and any payment assigned must be paid before the HOLD can be removed.

4.3.5 Resubmission while in Pending Review

An updated submission may be provided to the CMVP while in Pending Review if all the following rules are met:

1. This is not to be used as a placeholder, and the initial submission must have been the intended version on the specified environment to be validated. Penalties (e.g., ECR, or drop the module queue position) may be applied if misused. Acceptable (non-exhaustive) examples include:
    a. Code changes that strengthen the module's conformance claim (e.g., improve the granularity of the module's show version service, or reduce potential ambiguity with the module's approved service indicators).
    b. Changes under Section 4.3.6 number 1 (a, b, and c).
2. The updates must be allowed by and within the scope of the submission scenario, and full testing or regression testing may apply depending on the changes, following the requirements specified in Section 7.1 *Submission Scenarios*.

The updated submission will keep its place in the queue.

4.3.6 Changes while in Coordination

Changes during coordination for a FS or UPDT are permitted if all the following rules are met (subject to change, especially as Section 7.1 *Submission Scenarios* become available in Web Cryptik):

1. Changes are limited to one or more of the following:
    a. Quality / documentation updates to address CMVP checklist items or lessons learned from other module validations. Documentation improvements are encouraged to ensure accurate, high-quality reports and avoid ECR.
    b. In direct response to CMVP comments.
    c. Changes that would normally fit under: CVE or other vulnerability, NSRL,

TRNS, VUP, VAOE, OEUP[1], PTSC[1] and/or ALG. The requirements for these submission scenarios must be met per Section 7.1 *Submission Scenarios* (e.g., limited changes, regression testing, CAVP/ESV testing, etc.).

2. For items 1a and 1b (unless changes also fit under item 1c in which case see below):
    a. A summary of changes and where they apply (e.g., TEs, Security Policy section or Table) must be provided to the CMVP within the comments document itself.
3. For item 1c (even if changes also fit under items 1a or 1b):
    a. A separate Revalidation Change Document using the latest version is required per 7.1.1.

Notes:

a. Updates to improve documentation is encouraged to ensure accurate, high-quality reports and avoid ECR.
b. The review may be delayed for complexity (time incurred) depending on the impact of the changes.
c. Post-validation additional changes can be made using the revalidation scenarios per Section 7.1 of this document.
d. Code changes will impact compliance to AS04.13 due to new versioning. The Security Policy (Cryptik tables and SP template), the report (many TE assessments), PTR if any, and sometimes ESV (PUD) and CAVP certificates might also include the module version number and require updates.

4.3.7 Validation Deadline

CMVP may drop modules from the queue that have not completed the validation process within 2 years of being placed in REVIEW status. Should the modules approach the 2-year deadline, CSTLs have the option to contact the CMVP for reconsideration; CMVP will consider factors that contribute to the delay (e.g. if the delay was not due to CSTL or vendor unresponsiveness / inadequacy in addressing CMVP comments in a timely and efficient manner). When the module is dropped, the vendor and lab must restart the validation process including paying a new cost recovery fee at the current rate. This applies to all submissions currently in the process as well as to new submissions.

4.4 Validation when Test Reports are not Reviewed by both Validation Authorities

On rare occasions, laws from either country or other unusual circumstances prevent the release of product information outside its borders for specific products. In those occasions, both Validation Authorities will be advised of the circumstances, and the Validation Authority from that country will carry out the validation process on its own and present the certificate to the other Validation Authority for its signature (where applicable).

[1] Only permitted on a case-by-case basis with proper justification provided to the CMVP in advance of the resubmission. Considering the complexities of OEUP/PTSC, the CMVP may end up rejecting the proposal during Coordination and require a separate submission.

4.4.1 Controlled Unclassified Information

If a CMVP test report is received from a CSTL and it is identified in the signed letter of affirmation that it is subject to the International Traffic in Arms Regulations[2] (ITAR), the following CMVP programmatic guidance will be adhered to:

4.4.1.1 CMVP ITAR Guidance

1. Report submission as specified in Web Cryptik applies and should include the following changes from a normal submission:
    a. A proprietary security policy [PDF] submitted in lieu of a non-proprietary security policy.
    b. Provide a signed letter of affirmation from the vendor stating the applicability of ITAR to the submitted test report.
    c. To satisfy binding of Cryptographic Algorithm Validation Certificates, (see IG 2.3.A), the test report must affirm that the CSTL has PDF images (front and back) for any ITAR cryptographic algorithm validation certificates, where the algorithm website will not have any detailed information.
    d. The test report package is submitted only to NIST CMVP. The TID field will be formatted as: TID-*nn*-*nnnn*-ITAR. The characters ITAR will replace the field that was allocated for the CCCS TID.
    e. Actual module names, version numbers, and vendor information will be provided. This information will not be masked by dummy information.
2. Report review
    a. Each ITAR report will be reviewed by NIST reviewers only.
3. Certificate generation and posting
    a. Certificates will be prepared by NIST only.
    b. Certificates will be signed only by NIST. The CCCS signature field will be marked as: Not Applicable – ITAR.
    c. The NIST CMVP web page will only post the following information: Certificate number, applicable FIPS standard, Status, Module Type, Embodiment, Validation Date, Sunset Date and Overall Level. It will also include the testing Lab and associated NVLAP Code.
    d. The official certificate will be sent to the CSTL for presentation to the vendor.
4. Re-validation

---

[2] Example: **Not Releasable to Foreign Persons or Representatives of a Foreign Interest.**

INFORMATION SUBJECT TO EXPORT CONTROL LAWS of the UNITED STATES of AMERICA

Information subject to the export control laws. This document, which includes any attachments and exhibits hereto, may contain information subject to the International Traffic in Arms Regulation (ITAR) or Export Administration Regulation (EAR). This information may not be exported, released, or disclosed to foreign persons inside or outside the United States without first obtaining the proper export authority. Violators of ITAR or EAR are subject to civil and criminal fines and penalties under Title 22 U.S.C. Section 2778, and Title 50, U.S.C. 2410. Recipient **shall** include this notice with any reproduced portion of this document.

a. All re-validation changes will result in a new certificate sent to the CSTL for presentation to the vendor since the web site will not have any identifiable information.

b. Report submission, report review, certificate generation and posting as outlined above and following the submission requirements.

4.5 CMVP Fees[3]

4.5.1 Cost Recovery Program (CR & ECR)

Fees are charged to the CSTL by NIST CMVP to offset the cost of the validation authority activities performed by NIST CMVP. Cost Recovery (CR) fees are collected depending on the submission scenario as listed in Submission Scenarios. Extended Cost Recovery (ECR) fees are collected when the submission review exceeds the allotted resources and/or the submission results in one of the categories in 3.2.8 *Extended Cost Recovery*. The ECR fee is billed separately from any applicable CR fee.

Fees charged by NIST as part of the cost recovery program are listed at: https://csrc.nist.gov/Projects/cryptographic-module-validation-program/nist-cost-recovery-fees. Review of submissions will not begin until NIST CMVP receives confirmation that the invoice has been paid. CR fees cannot be reimbursed after the submission has entered the Review phase.

4.5.2 NIST Payment Policy

Only CSTLs with an active CRADA agreement can be invoiced. NIST CMVP maintains the billing information for each CSTL. If the CSTL's information needs to be updated (e.g., CSTL relocation), contact NIST CMVP. Upon receipt of the CSTL's submission or a request for an invoice, NIST billing (a separate office of NIST) prepares an invoice and submits it to the identified payee. For questions about methods of payments and associated handling fees contact NIST Billing Information: 301-975-3880 or at billing@nist.gov. In the event a cost recovery refund is warranted, the request must be directed to cmvplab@nist.gov.

4.5.3 Invoice for a Report Submission

The CR process is initiated upon receipt of the report submission or can be initiated before the report submission.

To initiate the CR process, the CSTL must send an IUTA (IUT-Add) using Web Cryptik indicating the correct number of modules, overall security level, and submission type. The IUTA can be submitted without requesting that the module be placed on the IUT List. The IUTA must be successfully processed by the NIST CMVP automated system. When the submission is successfully processed, the CSTL will receive an automated response, "*Thank you for your submission".*

At any time after the CSTL receives the automated response to the IUTA, the CSTL has the

[3] CCCS does not levy any charges for the validation of cryptographic modules.

option to send an IUTB (IUT-Billing) to initiate the CR process before submitting the report. When the IUTB is successfully processed, the CSTL will receive an automated response. Changes to the overall security level and submission type will not be accepted.

- If the CSTL sends an IUTB and then needs to cancel the invoice, the CSTL must send an IUTC (IUT-Cancel billing). When the IUTC is successfully processed, the CSTL will receive the automated response.
- Once the invoice has been paid, the payment may be refunded if the module submission is dropped prior to the REVIEW state.
- Only the module.json file is required for an IUTB or IUTC. For more information on this process, see the Web Cryptik help and User Guide.

Labs should note when the cost recovery process starts, no changes to the Security Level or Submission Type will be accepted. In addition, if a report has not been received by 90 days after the IUTB was accepted, the module will be moved to Hold and removed from the IUT List. The module can be automatically removed from Hold and placed on the MIP List by sending the report. If the lab chooses to not send an IUTB, the CR process will initiate upon receiving the report submission.

4.6 Flaw Discovery Handling Process

When a flaw is discovered in a **validated** cryptographic module and brought to the attention of the CMVP Validation Authorities, the following actions will be taken:

1. NIST, CCCS and the CSTL will investigate the allegation about the flaw, and determine its impact on the validation;
2. NIST and CCCS will decide whether the flaw requires the revocation of the validation, a caveat be placed on the entry in the *Cryptographic Module Validation List*, or no action;
3. NIST and CCCS may notify NVLAP about the possible shortfall in the CSTL's proficiency.

The diagram found in Annex A outlines the flaw discovery handling process. There are several ways for a flaw to be identified including a security-relevant CVE from the National Vulnerability Database (NVD).

4.7 Historical or Revoked Validations

Historical – Agencies may make a risk determination on whether to continue using this module based on their own assessment of where and how it is used. For more details, please visit the CMVP webpage: https://csrc.nist.gov/Projects/cryptographic-module-validation-program/validated-modules

If the validation certificate is historical, it will appear on the *CMVP Validation List* with the validation status *Historical*.

Examples that may result in a FIPS 140 validation being made historical by the CMVP:

- A validation implements cryptographic algorithm(s) in the approved mode that are no longer approved (e.g., an algorithm transition date has passed that was identified as one that will move the module to the historical list per the CMVP Programmatic Transitions webpage).
- Sunset date as shown on the validation is reached.
- A validation is bound to or embeds another validation that moved to the historical list (e.g., due to being sunset or an algorithm transition).

Revoked - The module validation is no longer valid, and this certificate may not be referenced to demonstrate compliance to FIPS 140-3.

If the validation certificate is revoked, it will appear on the *CMVP Validation List* with the validation status *Revoked*.

Examples that may result in a FIPS 140 validation being revoked by the CMVP:

a. Discovery of a security non-compliance or security flaw in a validated cryptographic module (typically one that would require module code changes to correct).

b. Discovery that the cryptographic module was validated using false information.

c. A CVE is discovered, and the module has been updated to mitigate the CVE. The module version with the CVE may be removed from the validation on the completion of the CVE submission which is effectively the same as revoking the validation for that version (see 7.1.11 CVE for more information).

d. Significant documentation issues that have a security impact to the operator of the module such as incorrect claims to:
    - Any of the items in *7.8 Module definitions for same certificates*,
    - Module Caveat,
    - Tested Configuration(s),
    - Versions (i.e., Software, Firmware, or Hardware),
    - Other CMVP documentation requirements (e.g., in IGs, MM, and SP 800-140 series) that have a security impact on the operator.

If an issue with a validation is discovered by the vendor or CSTL, the CMVP must be notified of the issue with a proposed schedule of when a correction will be submitted to the CMVP. The CMVP will consider the severity of the issues, the proposed timeline for correction, and if the issue was proactively requested (which is greatly encouraged/supported) when determining if the validation should be revoked or made historical. E.g., the CMVP may decide to keep the validation on the Active list until the revalidation submission that addresses the issue is completed.

The revalidation submission will either result in the same certificate being updated (whereby no further CMVP action needed), or it will result in a new certificate number in which case the original certificate may then be moved to the historical or revocation list. The CMVP may move the module to the historical or revocation list if the corrections are not made in a timely manner.

4.8 Entropy Source Validation (ESV) and Random Bit Generator (RBG) Processes

In April 2022, the CMVP introduced a new submission process called ESV for entropy sources leading to standalone entropy source validation certificates. The validation certificates provide the assurance that a particular entropy source on a particular operating environment conforms to SP 800-90B and associated IGs. In 2026, the CMVP introduced SP 800-90C testing for Random Bit Generators, and associated IGs. Both validation processes may be called ESV. Note, there is no Entropy Source Validation Program defined. The CMVP outlines entropy-related validation processes that are identified as ESV.

There are two environments that implement ESV testing: a Demo ESVTS, and a Prod ESVTS. The Demo environment is for testing and becoming familiar with the platform. The Prod environment is for certification. Only the Prod ESVTS will lead to interactions with the CMVP.

Prod ESVTS is the only mechanism the CMVP allows on a new submission that requires a validation on an entropy source or random bit generator construction. Entropy source validation is no longer accepted as part of a module submission (i.e., designated as ENT on the module certificate). Instead, the module submission must cite an existing entropy validation certificate or random bit generator construction certificate. See Section 7.1.14 for additional information on ESV and ENT claims.

The heuristic or stochastic model used to justify the entropy rate of the noise source must adhere to the requirements in SP 800-90B and the associated IGs. Particularly for non-physical noise sources this may be difficult. The CMVP expects a level of rigor in evaluating non-physical noise sources on par with efforts discussed within the CMUF Entropy Working Group.

Validation certificates for entropy sources (E#) do not have an expiration date. Entropy sources are evaluated using the current guidance available to the current standard and IGs at the time of ESV submission.

Questions on ESV can be sent to the CMVP or esv-prod@nist.gov.

4.8.1.1 Entropy Source Validation Submission Types

ESV Full Submission represents a request to create a new ESV certificate by demonstrating that an entropy source on a specific set of operating environments meets the requirements of the standards. All full submissions must meet the current guidance provided by the CMVP at the time of submission.

AddOE requests modify an existing ESV certificate to add new operating environment(s). An updated EAR and PUD are expected along with a DCA addressing the data collection requirements on new operating environments. The submission including the new operating environments must meet the current guidance provided by the CMVP at the time of submission, including the guidance on heuristics to justify entropy rates.

UpdatePUD requests are to correct or update the public use document associated with an existing ESV certificate. All UpdatePUD submissions must use the latest PUD template available on CSRC and meet the current documentation guidance provided by the CMVP at the time of submission.

RBG Full Submission requests can be done in conjunction with a Full Submission of an entropy source or referring to another random bit generator construction certificate or referring to an existing entropy source certificate. In the combined approach, a lab submits both the entropy source and the random bit generator construction to the CMVP at once. All RBG Full Submissions must include an RBG Report which justifies conformance of the random bit generator construction to the requirements in SP 800-90C. If an entropy source is included in the submission, all requirements of the ESV Full Submission apply. All full submissions must meet the current guidance provided by the CMVP at the time of submission

4.8.1.2 Entropy Source Validation Submission Procedures

To submit to ESVTS, a client must be used to interact with the server. The CMVP provides two clients for use: an HTML-based WebClient, and a Python client. Both have their advantages and features. It is encouraged that a lab is familiar with both options.

Several files are expected to be included in the submissions. It is the best practice to have these ready before making the initial request to ESVTS. The minimum set of files are as follows:

1. Entropy Assessment Report (EAR) – This file addresses the requirements in SP 800-90B and describes how the entropy source on the listed operating environments conforms to the standard and associated IGs.
2. Public Use Document (PUD) – This file provides information to a user that may incorporate or use the entropy source within a cryptographic module.
3. Data Collection Attestation (DCA) – This file addresses the SP 800-90B Section 3.2.4 requirements. The document must contain the name of each operating environment tested in this manner and a signature from the vendor representative. This file is optional, depending on how the data was collected from the entropy source. It may also be attached to the EAR instead of provided separately.
4. Data Files – These are files described in SP 800-90B that capture outputs from the entropy source. The files are subject to the SP 800-90B Entropy Assessment Tool available on GitHub. The number of files required depends on the entropy source being evaluated.
5. Random Bit Generator Report (RBG) – This file addresses the requirements in SP 800-90C and describes how the random bit generator construction(s) on the listed operating environments conforms to the standard and associated IGs.

Part of the certify step (which is the last step of the submission to the ESVTS) is the inclusion of an Entropy Identifier (EID) that will help the lab track the submission as it goes through the review process. The EID must be four alphanumeric characters and must not repeat with previous EIDs used by the lab. This is similar to the TID used within the module review process. A string used as an EID may still be used as a TID and vice versa.

After a submission is sent for certification the CMVP will perform cost recovery before the submission is passed along for manual review. During the manual review, two CMVP entropy reviewers will confirm the documentation provided addresses all of the SP 800-90B requirements.

If the ESV submission is designated as ITAR:

a. Provide a signed letter of affirmation from the vendor stating the applicability of ITAR to the submitted report.
b. Use a client to submit the entropy assessment to the API and upload the corresponding data files. The description field can be modified.
c. Use the designated NIST secure file communication tool to send the EAR, PUD, DCA, JSON metadata for ACVTS, and entropy assessment ID(s) to Chris Celi, christopher.celi@nist.gov.
d. Comment responses go ONLY to cmvpitar@nist.gov using PGP encryption. There is no ITAR flag in the EID.

An ESV certificate has a reuse status of either "Reuse restricted to vendor" or "Open for reuse".

"Reuse restricted to vendor" means:

a. Any module that has the same vendor can use the ESV certificate within their module with no additional permission, if the entropy source is portable to that module per the PUD guidance (e.g., identical environments, configuration steps, etc.).

b. The vendor's name of the ESV certificate must match exactly with the module vendor name, unless the two vendors are part of the same company (e.g., different divisions with slightly different names, or a company is a subsidiary of another company that has a validation). This vendor relationship would need to be explained with evidence provided to the CMVP as part of the module submission.

c. Someone other than the vendor can only use the certificate with written and signed permission from the vendor's point of contact (as indicated on the ESV certificate). The signed permission may be appended to the PUD of the certificate or be a separate document attached to the module submission package.

"Open for reuse" means any vendor can use that certificate within their module without any specific permission from the ESV certificate vendor. It does NOT mean the vendor can rebrand the ESV as their own.

4.8.1.3 Entropy Source Validation Web Client

The WebClient provides forms that guide a submitter through the process. All information must be submitted at once including the EAR, PUD, DCA, RBG, and data files. Once a request is submitted to NIST, the user is expected to store the resulting output presented by the WebClient at the end of the submission as the validation records. This provides a way to follow up on the request if needed. The URL to access the WebClient is the base URL of the ESVTS environment. The WebClient is available for both Demo and Prod.

4.8.1.4 Entropy Source Validation Python Client

The Python Client provides a more automated way of submitting data to ESVTS. Requests may be made piecemeal when information becomes available. The user is expected to store the outputs from the tool. The tool automatically logs important information. The Python Client is controlled with JSON files to drive the functionality needed at the time. This allows a user to

start making requests and pick them back up later. Configuration JSON files control if the Python Client is accessing Demo or Prod. The Python Client can be downloaded from the URL indicated in the Entropy Source Validation Webpages (Section 4.8.3)

4.8.2 Entropy Source Validation Comment Remediation Process

When an entropy source submission is picked up for review, the lab will receive an email about the change in status of the submission. The reviewers will evaluate the claims made in the EAR, and evaluate the information provided in the PUD. If there are questions or comments about the submission, a file will be sent to the lab with PGP-encrypted email for further clarification. The email will have the subject line "EID-XX-YYYY-{transaction code}-yyMMddHHmm" where XX is the lab code, and YYYY is the four-character EID provided during the certification request. On emails from the CMVP to the lab, the transaction code will be "CCOM#" where # is the number of comment rounds. For responses back to the CMVP, the lab must include the same subject line, but the transaction code must be "LCOM#" where the # matches the latest number sent from the CMVP. Only the changed files are required in the response email.

Updated documents in the comment remediation process must be named correctly for the CMVP's automated system. Do not include the old document in the email. Only one document can be tagged as an Entropy Assessment Report or a Public Use Document. If multiple meet the criteria, this could lead to an unintended document being published on the final entropy certificate.

For the document to be correctly tagged, the following case-insensitive substrings are searched for in the document name:

Entropy Assessment Report

- "Entropyassessmentreport"
- "Entropy" and "report" and ["assessment" or "analysis"]
- "_ear" or "_entropyreport"

Public Use Document

- "publicuse"
- "public" and "use"
- "_pud"

Data Collection Attestation

- "datacollectionattestation"
- "collection" and "attestation"

Random Bit Generator Report

- "randombitgenerator"
- "_rbg"
- "rbg" and "report"

Entropy Comment Document

- "_entropycomments." the "." indicates this should be at the end of the file name, where the "." is part of the file extension.

All other documents will automatically be tagged as "Other".

Any ESV submission that has substantial errors or requires significant additional review effort by the validators (e.g., due to issues with quality or complexity) will be subject to a NIST ECR (see HB 150-17 H.3.4.2).

4.8.3 Entropy Source Validation Webpages

For more information about the ESV Process, see https://csrc.nist.gov/Projects/cryptographic-module-validation-program/entropy-validations.

EAR and PUD Templates along with other documents are available at https://csrc.nist.gov/Projects/cryptographic-module-validation-program/entropy-validations/documents.

The ESV Certificate List is available on CSRC. See https://csrc.nist.gov/Projects/cryptographic-module-validation-program/entropy-validations/search.

For access to the Python Client and ESVTS on Demo or Prod, see https://github.com/usnistgov/ESV-Server.

4.9 CMVP Webpages

This section provides information about the CMVP program that can be found on the web.

4.9.1 Official CMVP Website

The official CMVP website with all current publicly-available information on the CMVP is https://csrc.nist.gov/Projects/Cryptographic-Module-Validation-Program. It can also be reached through https://nist.gov/cmvp.

4.9.2 Cryptographic Module Validation Lists

The official CMVP website can generate the following lists related to the validation of cryptographic modules:

- *Modules In Process* – A listing of the modules currently being reviewed by CMVP and the review state of each module. For more information about the MIP List, see section 4.2.

  This list is updated as additional information is available. The validation process is a joint effort between the CMVP, the CSTL and the vendor and therefore, for any given module, the action to respond could reside with the CMVP, the lab or the vendor. This list does not provide granularity into which entity has the action.

- *Implementation Under Test* – A listing of the modules currently being tested at the CSTL. This list is provided by the CSTLs and includes module name, vendor, FIPS

140-2 or FIPS 140-3, and the date when added to the list.

This list is updated as information is available. The IUT is under the control of the CSTL and the vendor. The CMVP is not aware of the submission schedule for these modules under testing.

- *Cryptographic Module Validation Search can be found at:* https://csrc.nist.gov/Projects/cryptographic-module-validation-program/validated-modules/Search
  - A basic search supports a single overall list or a list resulting from a combination of vendor, module name, or certificate number. The basic search only addresses active modules.
  - An advanced search will generate a single list with the following options:
    - Certificate Number:
    - Vendor:
    - Module Name:
    - Standard: (FIPS 140-1, FIPS 140-2, or FIPS 140-3)
    - Module Type:
    - Validation Status: (Active, Historical, or Revoked)
    - Embodiment:
    - Year Validated:
    - Overall Security Level:
    - Algorithm:
    - Allowed Algorithms:
    - Tested Configuration:
    - Caveat:
    - Hardware Versions:
    - Software Versions:
    - Firmware Versions:
    - Lab:

The search list is updated when new validation certificates are posted to the website. Only the current validation information is shown, however, changes are indicated in the validation history.

The lists are being improved as needs and time allows, so that more information than indicated here may be available from these sources before the next update of this document.

4.9.3 CMVP Certificate Page Links

Once the validation is identified, the information displayed typically includes vendor information, module information, and required caveats. For each certificate there are also several links from these pages that may be useful. These are described below.

4.9.3.1 Security Policy

This link is connected to the security policy that is the summary of the capabilities and security information of the module in a PDF format. The file is created under the agreement from the vendor and is available from the CMVP website.

4.9.3.2 Consolidated Validation Certificate

This link is connected to a list of certificates that were issued for the month of interest. It provides summary information that is accurate at the time of signing. For the latest module information, please refer to the certificate page. The file is created by CMVP and is from the CMVP website. Recent validations may not have this link available.

4.9.3.3 Vendor Link

This link is provided by the vendor to CMVP. The vendor is responsible for the accuracy of the link and the content. The CMVP does not endorse the views expressed or the information presented in the directed link, nor does it endorse any commercial products that may be advertised or available at the directed link.

4.9.3.4 Vendor Product Link

The purpose of this web link is for vendors to provide a concise listing of known products which incorporate their validated cryptographic module or, if the cryptographic module is a standalone product, additional relevant information about the product. The CMVP hopes that this link will make it easier for potential customers and users to identify products that use validated cryptographic modules.

The link in the certificate details page is to a vendor provided URL that is vendor created and vendor maintained. The provision of this Vendor Product Link by the vendor is optional. The CMVP does not endorse the views expressed or the information presented in the directed link nor does it endorse any commercial products that may be advertised or available at the directed link. Press releases are not accepted.

4.9.3.5 Algorithm Certificates

Links to the CAVP validation certificate for the approved algorithms used in the module are provided for those wishing to know more details to the specific testing performed. The link is from the CAVP website. This currently is under development and may change. Algorithm validation certificates can also be found in the security policy.

4.9.3.6 Validation History

The initial validation and all updates are shown along with the CSTL responsible. The validation shown includes all updates and is considered the official validation. If information concerning a revalidation is needed, contact the CSTL indicated on the validation certificate.

4.9.4 Usage of FIPS 140-3 Logos

Once validation is achieved CMVP will forward through the CSTL to the Vendor instructions about the use of the NIST FIPS 140-3 logo. Vendors who use validated modules in their products may also request use of the NIST FIPS 140-3 Logo. The request instructions and use requirements is available from the CMVP web site: https://csrc.nist.gov/Projects/cryptographic-module-validation-program/use-of-fips-140-2-logo-and-phrases. Completed forms are sent to cmvp@nist.gov.

5 CMVP and CAVP Programmatic Metrics Collection

This section provides an overview of the CMVP and CAVP Programmatic Metrics Collection and a description of the collection and reporting processes of the CMVP metrics.

5.1 Overview

The CMVP Programmatic Metrics Collection process is intended to document the quality performance of the testing and validation processes of the CMVP and to allow the program to evaluate its relevance within the government. To achieve these objectives various metrics are collected through the testing and validation processes of the CSTLs and the CMVP. These metrics are intended to identify general programmatic trends and not to measure individual CSTL or vendor performances.

5.2 Confidentially of the Collected Metrics Data

The CMVP considers the data collected and reported by the individual CSTLs as proprietary. CMVP makes every effort to anonymize the information by sampling only larger data sets and combining them without tracking information. The statistical information derived from the collected data is considered to be non-proprietary.

5.3 Collected Metrics

With the migration to FIPS 140-3 and the changes in the collection tools, the CMVP are currently reevaluating the methods used to collect useful metrics. Though the program may follow much of the previous procedures, it is not possible at this time.

6 Test Tools

This section covers the testing tools CSTLs are expected to utilize in the testing and reporting of validation submissions. Where applicable, the title of the person responsible for the update and/or maintenance of the document is identified.

6.1 Web Cryptik

Web Cryptik is a required tool for the completion of module testing, and generation of documents that must be included in a formal submission from the CST. The Web Cryptik tool is to be used to record details of the cryptographic module being tested, the specific testing performed, and the results of the validation testing. It is also to be used to create, among other documents, the FIPS 140 validation test report. Information about new features, enhancements, and bug fixes are provided with each release of the tool in the Web Cryptik User Guide.

The CMVP encourages suggestions, fixes, and improvements posted to the Github page https://github.com/usnistgov/CMVP/issues following the labels provided https://github.com/usnistgov/CMVP/labels.

Most submissions to CMVP are done through the use of Web Cryptik. The Web Cryptik User Guide provides a summary table of the submissions supported by Web Cryptik and files that must be included with the submission.

Responsible Individual: NIST CMVP Program Manager.

6.2 Suggested Tools for Physical Testing

As indicated in HB 150-17 Section B.6.4.2, a CSTL must meet the minimum hardware and software requirements for physical security testing. The CSTL can determine which tools to use to meet the requirements. All measurement equipment used to meet specific criteria in the conformance testing must have a valid calibration certificate from a separate accredited calibration laboratory. All equipment with storage capabilities must meet CSTL security policies. Personal equipment is prohibited for use in testing.

Below are some examples of tools for physical testing:

- X-Acto or Utility "Type" knives (including various blades)
- Strong artificial light source (Wavelength range of 400nm to 750nm)
- Magnifying glass
- Dremel "Type" Rotary Tool (including accessory bits: cutting, grinding, drilling, carving, etc.)
- Jeweler's screwdrivers (e.g., flat, phillips, robertson, torx, hex key)
- Dentist “Type” Instruments (e.g., picks and mirrors)
- Razor Saw
- Small pliers (e.g., needle nose, standard nose, long nose, curved nose, side cutters)
- Hammer
- Chisels
- Fine (small) files
- Heat Gun or Heat Source

Spray Coolant
Digital camera (personal phones are not acceptable)
Digital scanner
Printer
ANSI C Compiler
Debugger or binary editor
Microsoft Office Professional
Adobe Acrobat Standard
Personal protection equipment for chemical testing (e.g., goggles, gloves)

The equipment below may require calibration if used to measure to a reference:

Volt-Ohm-Milliammeter (VOM) or Digital Multimeter (DMM)
Variable Power Supply
Digital Storage Oscilloscope and/or Logic Analyzer
Temperature Chamber

7 CMVP General Testing and Reporting Guidance

In order for CMVP to manage the program more efficiently, additional testing requirements are addressed below. Several of the issues that were under section G of the FIPS 140-2 Implementation Guidance are presented in this section. This guidance does not change the cryptographic module requirements of ISO/IEC 19790:2012 but may impact ISO/IEC 24759:2017 documentation and testing requirements.

7.1 Submission Scenarios

An updated version of a previously validated cryptographic module can be considered for a *revalidation* rather than a *full validation* depending on the extent of the modifications from the previously validated version of the module. (Note: the updated version may be, for example, a new version of an existing cryptographic module or a new model based on an existing model.)

7.1.1 Requirements for all revalidations

For any revalidation, the vendor is responsible for reviewing all FIPS 140-3 requirements and making sure any change has been addressed throughout the module requirements and that proper documentation has been completed and submitted to the CSTL. The CSTL is responsible for an independent evaluation of the impacts throughout the module requirements for any change and performs any testing needed prior to submission. The CSTL **shall** address all affected TEs and the CSTL's assessment. The details **shall** be included in an updated Web Cryptik package with a summary of the changes listed in the latest version of the Revalidation Change Document (https://csrc.nist.gov/projects/cmvp/sp800-140b).

For all revalidations, the Web Cryptik package (or email package if that scenario is not yet available via Web Cryptik) **shall** include all information required by that revalidation scenario. The ZIP file and files within the ZIP file **shall** follow the requirements in the Web Cryptik User's Guide and be submitted to the CMVP using the specified data protection methods. Additional documentation may be required if CMVP guidance requiring the additional documentation has been published since the module's original validation.

All validation and revalidation scenarios **shall** be processed and submitted to the CMVP by a CSTL.

If a CSTL has been contracted to perform a revalidation for a validated module for which the CSTL did not perform the original testing on the base module:

a. The vendor **shall** provide the CSTL with the design documentation and implementation (including source code, HDL, etc.) of the base validated module and of the module that has been updated. The exception to this requirement is for VUP and VAOE revalidations.

b. The vendor **shall** provide the CSTL with the latest Security Policy as shown on the base module's most recent certificate (this includes the JSON files and information necessary to generate the Security Policy for SP 800-140Br1-compliant base modules).
c. The vendor **shall** provide the CSTL with the latest base module validation report (a.k.a. Test Report) for the following revalidation scenarios: INTU, NSRL, ALG, OEUP, PTSC, UPDT, CVE and TRNS. This is to ensure the new CSTL has the original tests to confirm if regression testing is necessary in addition to the minimum required by that revalidation scenario.
d. The vendor **shall** provide the CSTL with the latest base module physical test report (a.k.a. PTR), as applicable, for the following revalidation scenarios: INTU, NSRL, UPDT, CVE, TRNS and PHYS. This is to ensure the new CSTL has the original tests to confirm if physical testing was impacted (e.g., changes to the physical enclosure or changes to firmware that controls the physical response logic).
e. The CSTL **shall** determine that the provided base documentation and implementation is identical to the base validated module.
f. The CSTL **shall** examine each modification and confirm that the change is appropriate for the submission type (e.g., non-security relevant for NSRL).
g. The CSTL **shall** determine that no other modifications, including unintentional, have been made to the base module apart from what is permitted by the revalidation scenario.
h. The CSTL submissions **shall** meet all requirements of the revalidation scenario.
i. The CSTL submission **shall** indicate which submission scenario is applicable and a summary of associated changes in the Revalidation Change Document.
j. The CSTL **shall** use the Revalidation Change Document format for listing the certificate information as required by each revalidation scenario.
k. The CSTL **shall** submit, at a minimum, what is listed in the below sections as required by the revalidation scenario.
l. The CSTL **shall** be responsible for all content of the module validation, including module claims made, quality of documentation, and FIPS 140-3 conformance testing performed even if originally done by another lab, for the following revalidation scenarios: UPDT, INTU. In these cases, labs may need to re-do parts of the testing or improve areas of the validation outside of the revalidation changes. Labs also have the option to inform the CMVP to place these modules in question on HOLD while improving the submission. For revalidation scenarios other than UPDT and INTU, the new CSTL is responsible only for the module contents and testing that are impacted by the revalidation scenario.

Below are the twelve possible FIPS 140-3 submission scenarios: Full Submission (FS), Vendor Update (VUP), Vendor Affirmed Operational Environment (VAOE), Non-Security Relevant (NSRL), Algorithm Update (ALG), Operational Environment Update (OEUP), Rebrand

(RBND), Port Sub Chip (PTSC), Update (UPDT), Common Vulnerabilities and Exposures (CVE), Algorithm Transition (TRNS), and Physical Enclosure (PHYS).

See section 7.1.14 for a summary table and submission process for each of these submission scenarios, and section 7.1.15 for additional comments.

7.1.2 Full Submission (FS)

The first time a new software, firmware, hardware, or hybrid module is submitted for validation. The module **shall** meet all applicable requirements at the time of submission.

If modifications are made to hardware, software, or firmware components that do not meet any of the below revalidation criteria, then the cryptographic module **shall** be considered a new module and **shall** undergo a full validation testing by a CSTL and submitted as a FS.

7.1.2.1 Interim Validation

This is a temporary measure to shorten the queue and expand the active validations. These validations are valid for two years only but can be converted to a normal full validation (with a 5-year validation date) on the completion of an additional conversion/submission compliant to SP 800-140Br1.

The main difference from a normal validation is that for interim validations, the CMVP depends more on the CSTL submission with less CMVP oversight.

For information on revalidation rules for interim validations, please contact a CSTL who has received additional information from the CMVP.

For more general information in interim validations, see the CMVP webpage: https://csrc.nist.gov/projects/cryptographic-module-validation-program/programmatic-transitions.

7.1.2.2 Br1 Update to Interim (INTU)

Follow-up submission to an interim validation to remove the interim status and extend the sunset date of the validation to five years. This INTU submission must be received by the CMVP (via WebCryptik) prior to the two-year sunset date to prevent the interim validation moving to the historical list.

An INTU submission complies with the SP 800-140Br1 format and other documentation guidance at the time of the INTU submission (e.g., TE Documentation Guidance).

An INTU would:

1) Upon submission, update the sunset date of the existing interim validation to 5 years from the interim validation date (i.e., add 3 more years).
2) Upon successful review and completion
    a. Generate a new certificate that will:
        i. Be compliant to SP 800-140Br1.

ii. NOT have the interim validation status.

iii. Have a sunset date of 5 years from the interim validation date.

b. Move the interim validation certificate to the historical list with the Historical Reason pointing to the new/replaced (SP 800-140Br1-compliant) certificate.

The CSTL **shall**:

a. Be the same CSTL as the original validation, unless section 7.1.1 requirements are met for a new CSTL.
b. Ensure the INTU submission complies with the SP 800-140Br1 format and other documentation guidance at the time of the INTU submission (e.g., TE Documentation Guidance).
c. Ensure no module code changes were made.
d. Submit the same package contents as an FS including a Test Report updated to the latest guidance that uses the original Test Report as a baseline.

7.1.3 Vendor Update (VUP)

Administrative updates (e.g., updating vendor contact information, grammatical Security Policy corrections). These would NOT impact FIPS 140-3 requirements.

7.1.4 Vendor Affirmed Operational Environment (VAOE)

Security policy change of vendor affirmed OEs (see Management Manual 7.9 *Vendor or User Affirmation of Modules*).

7.1.5 Non-Security Relevant (NSRL)

Modifications are made to hardware, software or firmware components that do not affect any FIPS 140-3 security relevant items. Per IG 2.4.A, "the term *security* is not defined in the Terms and Definitions, but, within the scope of FIPS 140-3, is determined based on the Section 6 Functional Security Objectives, and the specific Section 7 Security Requirements derived from those objectives". The CSTL is responsible for identifying the documentation that is needed to determine whether a revalidation is sufficient, and the vendor is responsible for submitting the requested documentation to the CSTL. Documentation may include a previous validation report, design documentation, source code, source code difference evidence, FSM, security policy differences, etc.

The CSTL **shall**:

a. Review and independently verify the accuracy of the vendor-supplied documentation and identify any additional documentation necessary to confirm the applicability of this revalidation scenario.
b. Determine additional testing as necessary to confirm that FIPS 140-3 security relevant items have not been affected by the modification.

c. Identify the assertions affected by the modification and **shall** perform the tests associated with those assertions. This will require the CSTL to:
   i. Review the COMPLETE list of assertions applicable to the module,
   ii. Identify, from the previous validation report, the assertions that have been affected by the modification,
   iii. Identify additional assertions that were NOT previously tested but should now be tested due to the modification, and
   iv. Review assertions where specific Implementation Guidance (IG) was provided at the time of the original validation to confirm that the module still meets the IG as it existed at the time of the original validation.

d. Perform tests identified in b and c above (expected to at least include AS04.13 to reflect the new version(s) as a result of the code changes) on all new version(s) listed on the module's certificate on at least one configuration of one module as defined per the module count guidance under "MIS Field Descriptions". Additionally for software/firmware/hybrid modules, tests must be done on at least one listed OE. This assumes the new versions compile to the same binary across all modules and configurations. If new versions compile to different binaries, then each binary must be tested separately.
   i. E.g., a hardware validation has two 'base' modules (i.e., P/N 10 and P/N 20) that map to the following firmware components: P/N 10 uses firmware components 1.0 and 2.0, and P/N 20 uses firmware components 1.1, 2.0, and 3.0 (note, the same firmware component, 2.0, is shared between both 'base' modules). If NSRL changes were made to firmware component 2.0 (now version 2.1) but no changes were made to firmware components 1.0, 1.1 and 3.0, it is sufficient for the CSTL to test either: 1) P/N 10 using 1.1 and 2.1, or 2) P/N 20 using 1.0, 2.1, and 3.0. This assumes firmware component 2.1 compiles to the same binary for P/N 10 as it does for P/N 20. If not, P/N 10 and P/N 20 would each need to be separately tested.
   ii. If regression testing is not performed on some versions, configurations, and OEs, then those **shall** be removed from the module's certificate UNLESS the CSTL provides proper justification on why regression testing is not necessary for the untested versions, configurations and OEs. With proper justification, these may remain on the module's certificate.

NSRL code changes ("limited" or not) would NOT require retesting CAVP certificates (even if otherwise applicable per the CAVP FAQ GEN.9), since changes are non-security relevant and verified by the CSTL as having no impact to the algorithm implementations or how it meets CAVP testing. CAVP FAQ GEN.11 may be leveraged to update the CAVP versioning information if changes are made outside the algorithm boundary but still impact the versioning on the CAVP certificate (e.g., the CAVP versioning reflects the module boundary rather than the algorithm boundary).

The CSTL may send the CMVP a Request For Guidance to confirm their analysis on the non-security relevant changes prior to submission, which is expected to address at least the following questions:

1. What changes are being proposed?
2. What is the justification that each change is considered non-security relevant? E.g., changes are NOT to any items from 7.8 Module definitions for same certificates or other areas that affects how the module meets the security objectives and requirements of FIPS 140-3.

Note, even though NSRLs are generally code changes, documentation-only modifications would still fall under an NSRL as opposed to a VUP if those modifications affect assertions that must be reassessed/retested by the CSTL. For example, if a module name is changed but the module identifier remains unchanged, the CSTL would have to reassess compliance to AS04.13 (and AS02.13) but this wouldn't necessarily require code changes to the versioning output service. Thus, the NSRL would capture these limited regression tests even though code changes remain unchanged.

7.1.6 Algorithm Update (ALG)

Post validation, approved security relevant functions or services for which CAVP testing was not available (or vendor affirming was still permitted per the CMVP/CAVP transition schedule) at the time of submission to the CMVP for validation are now CAVP-tested and are being submitted for inclusion as an approved function or service. The CSTL is responsible for identifying the documentation that is needed to determine whether a revalidation is sufficient, and the vendor is responsible for submitting the requested documentation to the CSTL. Documentation may include a previous validation report and applicable CMVP rulings, design documentation, source code, security policy differences, etc. Code or configuration changes are not permitted under this revalidation scenario. For example, if self-tests are required for approved algorithms, the module must already support these self-tests. In essence, this means that ALG can only be used when a previously vendor affirmed or allowed algorithm that was available in the approved mode now has CAVP testing available and already meets the algorithm requirements (e.g., self-tests) and module requirements (e.g., approved service indicator).

The CSTL **shall**:

a. review and independently verify the accuracy of the vendor-supplied documentation and identify any additional documentation necessary to confirm the applicability of this revalidation scenario.
b. identify the assertions affected by the modification and **shall** perform the tests associated with those assertions. This will require the CSTL to:
    i. Review the COMPLETE list of assertions applicable to the module,
    ii. Identify, from the previous validation report, the assertions that have been affected by the modification,

iii. Identify additional assertions that were NOT previously tested but should now be tested due to the modification, and

iv. Review assertions where specific Implementation Guidance (IG) was provided at the time of the original validation to confirm that the module still meets the IG as it existed at the time of the original validation, except for IGs related to the newly tested algorithm where the latest IGs **shall** be met.

7.1.7 Operational Environment Update (OEUP)

No changes to the module with an addition, modification, or deletion of tested operational environments (OEs). Purely deleting OEs can be done as a NSRL, but deleting can be done within an OEUP if also adding and/or modifying OEs. This **shall** require CAVP-testing the algorithm validations on the new/modified OEs. If an entropy source assessment is applicable per IG 9.3.A, ESV(s) to cover all new/modified OEs and/or platforms **shall** be submitted and validated separately prior to submission. The CSTL **shall** perform the full regression test suite shown on the CMVP website.

The only time code changes are allowed as part of an OEUP is if they are non-security relevant and *necessary* to correctly run the module on the new/modified OE (e.g., compilation flags or configuration options that need to be updated). No other changes are permitted (even to incorporate other non-security relevant changes such as bug fixes). In Web Cryptik, this may be captured as a checkbox under the OEUP submission scenario (e.g., the CSTL selects "Limited NSRL").

Upon re-testing and validation, the CMVP provides the same assurance as the original OE(s) as to the correct operation of the module on the new/modified OE(s). The new/modified OE will be added to the module's validation entry.

As a potential alternative to an OEUP, module vendors and users may take advantage of the porting provisions explained in 7.9 (Vendor or User Affirmation of Modules) of this document.

7.1.8 Rebrand (RBND)

This scenario applies if there are no modifications to a module and the new module is a re-branding of an already validated Original Equipment Manufacturer (OEM) module. Any module type can be rebranded.

The CSTL **shall**:

1. determine that the re-branded module is identical to the OEM module (n.b. this requirement applies equally to open source and non-open-source modules).
2. include the OEM's written approval for re-branding in the submission package which **shall** note the terms of permission (e.g., subsequent addition of OEs, possible re-use of CAVP certificates, entropy, non-security relevant changes, remediation of CVE, whether a rebrand of a rebrand is acceptable, etc.) including who owns/controls the codebase and is responsible for updates to it post validation. E.g., if these terms do not explicitly allow a vendor to further rebrand the OEM module, then a rebrand of that rebranded module is not permitted unless written permission is granted by the OEM.

3. (for modules containing any open-source licensed code) ensure the open-source licensing requirements are met (e.g., any required notices are contained in the Security Policy).

A RBND **shall** include at least one OE from the original validation and cannot add new OEs. With proper OEM permissions, a RBND followed by a separate OEUP submission can accomplish rebranding a module on different OEs.

The only time it is allowed to combine a RBND with other scenarios is as follows:

a. A RBND may be combined with a PHYS only if physical changes are *necessary* to correctly rebrand the module. For example, if the paint or coating on the hardware of the rebranded module is changed to reflect the new company's color schemes, and/or to change the vendor and product names on the enclosure. In Web Cryptik, this may be captured as a checkbox under the RBND submission scenario (e.g., the CSTL selects "PHYS").

b. The only time code changes are allowed as part of a RBND is if they are *necessary* to correctly rebrand the module (e.g., to display the new module name/version/logo, or to use the new vendor's color schemes/visual aesthetics). No other changes are permitted (even to incorporate other non-security relevant changes such as bug fixes). In Web Cryptik, this may be captured as a checkbox under the RBND submission scenario (e.g., the CSTL selects "Limited NSRL").

c. A RBND is essentially guaranteed to be combined with a VUP to address the vendor changes so this will not be separately selectable in Web Cryptik.

d. A vendor is expected to have permission to reuse the OEM's CAVP certificates. Therefore, addition to CAVP certificate information is NOT permitted as part of a RBND (but if permission is granted by the OEM, may be part of a post-RBND revalidation such as a UPDT).

The CSTL **shall** provide an updated security policy which is technically identical to the originally validated security policy and describes the re-branded module.

7.1.9 Port Sub Chip (PTSC)

A sub-chip cryptographic subsystem that was previously validated in a single-chip (see IG 2.3.B) can be ported to other single-chip constructs as a PTSC submission to the CMVP. The following is applicable to validate this new single-chip module:

a. The CSTL **shall** verify that there are no security relevant changes in the sub-chip cryptographic subsystem;

b. If an entropy source is contained within the sub-chip cryptographic subsystem, ESV(s) to cover all new single-chip environments **shall** be submitted and validated separately prior to submission;

Note 1: An ESV may not be required, if the entropy is collected outside the sub-chip cryptographic subsystem, depending on changes to the entropy source or the

subsystem housing it. Please refer to IG 9.3.A and IG D.J for details on applicable caveats and entropy estimates.

Note 2: Single chip embodiments may implement an ESV or a DRBG linked to a dedicated entropy source inside the physical boundary. Such cases may be implemented (a) inside the sub-chip cryptographic subsystem or (b) in two or more sub-chip cryptographic subsystems. The case (b) represents multiple disjoint sub-chip cryptographic subsystems (see Resolution 3 of IG 2.3.B).

c. Approved security functions **shall** be retested and validated by the CAVP if implemented in a soft circuitry core recompiled in a different part configuration. In Web Cryptik, this case may be captured as a checkbox under the PTSC submission scenario (e.g., the CSTL selects "CAVP Testing Redone").

Note 3: If the original algorithm testing was performed as stated in the Management Manual Section 7.3 – *Testing using Emulators and Simulators* in a module simulator, and there is no change to the soft-core, no additional algorithm testing is required.

d. Full regression testing (see FIPS 140-3 Resources page) **shall** be performed on the new sub-chip cryptographic subsystem after fabrication (transformation of the HDL to a gate or physical circuitry representation);
e. **ISO/IEC 19790:2012** Section 7.3 **shall** be addressed for the new single-chip module for all Security Levels within this Section.
f. **ISO/IEC 19790:2012** Section 7.7 **shall** be addressed for the new single-chip module at Security Level 1.
g. **ISO/IEC 19790:2012** Sections 7.11.2 and 7.11.9 **shall** be addressed for the new single-chip module for all Security Levels within this Section.
h. A new Security Policy **shall** be provided for the new single-chip module.
i. Versioning information on the new certificate **shall** be provided for:
    - the new physical single-chip,
    - non-security relevant single-chip functional subsystem firmware if applicable,
    - the sub-chip cryptographic subsystem soft and hard circuitry cores (which are unchanged from the original validation), and
    - the associated firmware.
j. The only time code changes are allowed as part of an PTSC is if they are non-security relevant and *necessary* to correctly run the module on the new/modified single chip environment (e.g., compilation flags or configuration options that need to be updated). No other changes are permitted (even to incorporate other non-security relevant changes such as bug fixes). In Web Cryptik, this may be captured as a checkbox under the PTSC submission scenario (e.g., the CSTL selects "Limited NSRL").

7.1.10 Update (UPDT)

Modifications are made to hardware, software or firmware components **that affect some of the FIPS 140-3 security relevant items**. Per IG 2.4.A, "the term *security* is not defined in the Terms and Definitions, but, within the scope of FIPS 140-3, is determined based on the Section 6 Functional Security Objectives, and the specific Section 7 Security Requirements derived from those objectives". An updated cryptographic module can be considered in this scenario if less

than a 30% of security changes were made to the module. Security changes include impacts to: approved / allowed security functions/algorithms, SSPs, approved security services, self-tests, and security states within the FSM. None of these, assessed individually, can exceed 30% of changes. The individual ratios for each of these **shall** be provided to the CMVP within the Revalidation Change Document (e.g., 2 changes to approved security services out of 10 total results in 20% change).

The CSTL is responsible for identifying the documentation that is needed to determine whether a revalidation is sufficient, and the vendor is responsible for submitting the requested documentation to the CSTL. Documentation may include a previous validation report and applicable CMVP rulings, design documentation, source code, source code difference evidence, FSM etc.

The CSTL **shall**:

a. provide a summary of the changes and rationale of why this meets the <30% guideline. The CMVP upon review, may determine that the changes are >30% and **shall** be submitted as an FS.
b. review and independently verify the accuracy of the vendor-supplied documentation and identify any additional documentation necessary to confirm the applicability of this revalidation scenario.
c. identify the assertions affected by the modification and **shall** perform the tests associated with those assertions. This will require the CSTL to:
    i. Review the COMPLETE list of assertions applicable to the module,
    ii. Identify, from the previous validation report, the assertions that have been affected by the modification,
    iii. Identify additional assertions that were NOT previously tested but should now be tested due to the modification, and
    iv. Review assertions where specific Implementation Guidance (IG) was provided to confirm that the module meets all current applicable IGs.

In addition to the tests performed against the affected assertions, the CSTL **shall** perform the regression test suite shown on the CMVP website.

The UPDT can also be used to for resetting the module's sunset date when a module has not changed, provided the above requirements are met.

UPDT can be combined with any submission scenario(s). In Web Cryptik, there may be an option for the CSTL to select the appropriate checkbox(s) after choosing the UPDT submission scenario.

7.1.11 Common Vulnerabilities and Exposures (CVE)

A CSTL has been contracted to perform a revalidation for a module on which the vendor has made FIPS 140 security-relevant changes in response to one or more CVEs (Common Vulnerability and Exposure) or one or more security relevant maintenance/bugs. For more information about CVEs please see https://cve.mitre.org/.

This revalidation scenario provides the vendor with a means to quickly fix, test, and revalidate a module subject to a *security-relevant* CVE or maintenance/bug fix [1] while at the same time providing assurance that the module still meets the FIPS 140-3 standard. If a CVE or maintenance/bug fix does not require security-relevant changes to address it, then the vendor may instead pursue an NSRL revalidation.

To complete a Scenario CVE revalidation:

a. The CSTL **shall** determine that security relevant changes to the module are only to correct the vulnerability disclosed in the CVE or to maintain the module's compliance/security claims/objectives via code corrections or bug fixes (e.g., self-tests operate incorrectly on certain OEs that were not part of the module validation). Changes **shall** not introduce new features or cryptography and **shall** be consistent with Section 7.8 Module definitions for same certificates (i.e., the new version must be identical in the defined areas when compared against the original version, even if the original version ends up being removed from the certificate upon completion of the CVE Submission). Other changes are permitted if only directly impacted by the CVE or maintenance/bug change (e.g., addressing the CVE or maintenance/bug may require changing the version number, and that requires the show version service to be updated). In WebCryptik, this may be captured by selecting "Limited NSRL" checkbox after choosing the CVE submission scenario.
b. The CSTL **shall** examine each modification and confirm that the change does not conflict with the requirements of FIPS 140-3.
c. The CSTL **shall** determine that no other modifications have been made.
d. The CSTL **shall** identify the assertions affected by the security-relevant modification and **shall** perform the tests associated with those assertions.
e. The vendor is not required to address IGs that have been published since submission of the original module, besides, for CVE changes, following the continual guidance of IG 11.A (CVE Management).
f. If the fix to address the CVE or maintenance/bug is in the scope of an algorithm implementation (e.g., involves a change that requires retesting per the CAVP), then this algorithm **shall** be CAVP tested again to obtain a new CAVP certificate with the new module version. In this case, the CSTL selects something to the effect of a "CAVP Testing Redone" sub-option in Web Cryptik after choosing the CVE submission scenario.

In addition to the tests performed against the affected assertions, the CSTL **shall** also perform the predefined regression tests shown on the CMVP website, under CVE.

Because the change to the module is to address a security-relevant CVE or maintenance/bug, **the previous version of the module is no longer considered validated (in essence, Revoked) and shall be removed from the certificate**; exceptions may be made if the vendor shows how the

CVE or maintenance/bug can be mitigated by policies included in the Security Policy, while still adhering to the FIPS 140-3 standard.

[1] A *security-relevant* CVE or maintenance/bug fix is one that affects how the module meets the Section 6 Functional Security Objectives, and the specific Section 7 Security Requirements derived from those objectives.

7.1.12 Algorithm Transition (TRNS)

A CSTL has been contracted to perform a revalidation for a module on which the vendor has made FIPS 140-3 security relevant changes solely in response to a published CMVP algorithm transition that will cause some previously validated modules to be placed on the Historical list (see Programmatic Transitions webpage for a list of such algorithms). For example, the 2024 non-SP 800-56Brev2 RSA-based key encapsulation/un-encapsulation transition explained in FIPS 140-3 IG D.G. If the algorithm transition will NOT cause the module to move to the historical list (i.e., considered a "soft" transition), changes cannot be made as part of this submission.

Note: a single Scenario TRNS submission may combine multiple algorithm transitions. However, this may increase review time.

The purpose of the TRNS revalidation is to provide the vendor a means to quickly address algorithm transition requirements, test and revalidate a module in order to meet a CMVP transition, while at the same time providing assurance that the module still meets the FIPS 140-3 standard.

If the module code is *changed* to address an algorithm transition, the following requirements apply:

a. Submitted as a Scenario TRNS.
b. The CSTL **shall** determine that security relevant changes to the module are only to address a specific CMVP transition. Other changes are permitted if only directly impacted by the TRNS change (e.g., addressing the TRNS may require changing the version number, and that requires the show version service be updated). In Web Cryptik, this may be captured as a checkbox under the TRNS submission scenario (e.g., the CSTL selects "Limited NSRL").
c. The CSTL **shall** examine each modification and confirm that the change does not conflict with the requirements of FIPS 140-3.
d. The CSTL **shall** determine that no other modifications have been made. The vendor is not required to address IGs or guidance that have been published since submission of the original module, unless directly applicable to the transitioning algorithm (e.g., CAVP testing or self-test requirements).
e. The CSTL **shall** identify the assertions affected by the security-relevant modification and **shall** perform the tests associated with those assertions.
f. If the means to meet the transition are in the scope of an algorithm implementation, and the path chosen to meet the requirements necessitates testing,

then this algorithm **shall** be CAVP tested to obtain a new CAVP certificate with the new module version. In Web Cryptik, this may be captured as a checkbox under the TRNS submission scenario (e.g., the CSTL selects "CAVP Testing Redone").

g. In addition to the tests performed against the affected assertions, the CSTL **shall** also perform the predefined regression tests shown on the CMVP website under "TRNS – Code Change" on all versions listed on the module's certificate and on at least one of the listed OEs for hybrid or software/firmware modules (if the module binary image is identical across all OEs; if not, testing on at least every binary image is required).

h. The CSTL **shall** provide justification on why regression testing is not necessary for the untested OEs. With proper justification, these may remain on the module's certificate.

i. If regression testing is not performed on some versions, then those **shall** be removed from the module's certificate. OEs without proper justification or regression testing **shall** be removed from the module's certificate.

If the module code is *unchanged* to address an algorithm transition and the change is purely to documentation, one of the following four options apply. For each option, the CSTL **shall** state that the change to address the transition is purely documentational and which option applies.

Option 1: services or functionality were not moved to or from an approved mode to remain compliant (e.g., services remain in an approved mode but are updated to demonstrate compliance to the applicable algorithm standard rather than moved into a non-approved mode), then the vendor may pursue a Scenario ALG revalidation.

Option 2: The vendor moves all non-compliant functionality into a non-approved mode of operation from an approved mode of operation.

a. Submitted as a Scenario TRNS.

b. The CSTL **shall** determine that security relevant changes to the module are only to address a specific CMVP transition.

c. The CSTL **shall** examine each modification and confirm that the change does not conflict with the requirements of FIPS 140-3.

d. The CSTL **shall** determine that no other modifications have been made. The vendor is not required to address IGs or guidance that have been published since submission of the original module, unless directly applicable to the transitioning algorithm (e.g., CAVP testing or self-test requirements).

e. The CSTL **shall** identify the assertions affected by the security-relevant documentation modification and **shall** perform the tests associated with those assertions.

f. The CSTL **shall** demonstrate how the module still meets IG 2.4.C after the reclassification of non-compliant functionality into a non-approved mode of operation. Due to this FIPS 140-3 requirement that all approved security services

have an unambiguous indicator (AS02.24), **it does not seem likely/possible that a FIPS 140-3 validation fall under this Option 2**, where code is unchanged yet a previously approved service is moved to the non-approved mode, as that would surely invalidate the approved indicator for this service.

g. In addition to the tests performed against the affected assertions, the CSTL **shall** also perform the predefined regression tests shown on the CMVP website under "TRNS - No Code Change" on all versions listed on the module's certificate and on at least one of the listed OEs for hybrid or software/firmware modules (if the module binary image is identical across all OEs; if not, testing on at least every binary image is required).

The only exception to this requirement (g.) is if the algorithm being transitioned is part of a standalone service and is not used by any other module service (e.g., cryptographic library where the module only provides the algorithm as an API service to a calling application as a stand-alone service). In this case, the CSTL **shall** provide justification on why regression testing is not necessary at all.

j. The CSTL **shall** provide justification on why regression testing is not necessary for the untested OEs. With proper justification, these may remain on the module's certificate.

k. If regression testing is not performed on some versions, then those **shall** be removed from the module's certificate. OEs without proper justification or regression testing **shall** be removed from the module's certificate.

h. The CSTL **shall** provide assurance that the non-compliant functionality is not used to meet any FIPS 140-3 requirements (key/CSP establishment, generation, storage, etc.).

i. The CSTL **shall** provide assurance, upon module examination, that no service, algorithm or CSP that relied on or used the non-compliant functionality, parameters, keys, etc. remain in an approved mode. An approved mode **shall** only contain approved services.

j. Documentation **shall** be updated to indicate the module does not utilize non-compliant functionality in an approved mode of operation.

Option 3: The vendor recategorizes the non-compliant functionality as claiming no security per IG 2.4.A, and this functionality remains in an approved mode of operation.

a. The same rules for Option 2 above **shall** be followed except for bullets 'i' and 'j'.

b. The CSTL **shall** provide justification on how the requirements of IG 2.4.A are met. This scenario is intended to be rarely used/accepted and depends on the purpose or use of the service that utilizes the non-approved algorithms. For example, a software library implementing three-key Triple-DES Encryption as one of its approved services cannot simply state this algorithm does not claim any security (per IG 2.4.A) and be used in an approved mode, as this does not meet 3) or 4) in IG 2.4.A Additional Comment #2.

Option 4: A combination of any of three options above (ALG, moving non-compliant functionality into the a non-approved mode, and/or recategorized per IG 2.4.A), in which case, requirements of each option apply.

a. Submitted as a Scenario TRNS.
b. Each option **shall** be listed/indicated in the Revalidation Change Document under Option 4 (e.g. under Option 4, the following are claimed: Options 1 and 2) and note how each of the applicable 'shall' statements for each option are met).

In order to accommodate vendors who are updating their validation to prepare for an algorithm transition, fully compliant TRNS or ALG revalidations that have addressed the transition and are submitted to the CMVP before the date the transition is to take effect, will remain on the active list through the completion of the revalidation, even if it is not completed until after the transition date, unless the algorithm transition is to address a security concern that is deemed unacceptable by the CMVP. For newly submitted ALG submissions that address the transition, the CSTL **shall** include in the Special Instructions field the text "algorithm_transition" (with or without the underscore) in order for the CMVP not to move this submission to the historical list come the algorithm transition date.

Changes made to a module in order to meet a transition are security-relevant, whether to the module code or purely to documentation, due to their potential impacts on core and downstream services and the treatment of keys and SSPs. For example, moving *allowed* functionality from an approved mode to a non-approved mode - by either changing the software/firmware or a purely documentation change - is considered security relevant. Therefore, besides the case in **Option 1** above, all submissions that address a transition will require a Scenario UPDT, TRNS or FS submission regardless of module type or security level.

If a Scenario TRNS revalidation addresses an algorithm transition that moved the original certificate to the Historical list, and the sunset date of the certificate has yet to expire, then upon the revalidation of the module under Scenario TRNS, a new certificate will be issued on the Active list (inheriting the original sunset date) for the version of the module compliant with the transition requirements. Otherwise, if the original certificate was moved to the Historical list for reasons that are not addressed in the TRNS revalidation (e.g., a separate algorithm transition or the sunset date expired), the new certificate will be shown on the Historical list *immediately* after completion of the TRNS revalidation.

7.1.13 Physical Enclosure (PHYS)

Modifications are made only **to the physical enclosure of the cryptographic module that provides its protection and involves no operational changes to the module**. The CSTL is responsible for ensuring that the change only affects the physical enclosure (integrity) and has no operational impact on the module. The CSTL **shall** fully test the physical security features of the new enclosure to ensure its compliance to the applicable requirements of the standard.
The CSTL **shall**:

a. Describe the change (pictures may be required),
b. State that it is a security relevant change,

c. Provide sufficient information supporting that the physical only change has no operational impact,

d. Describe the tests performed by the CSTL that confirm that the modified enclosure still provides the same physical protection attributes as the previously validated module. For physical security levels 2, 3 and 4, the CSTL **shall** submit an updated Physical Security Test Report.

The only time code changes are allowed as part of an PHYS is if they are non-security relevant and *necessary* to correctly run the module on the new/modified physical enclosure (e.g., changes to the enclosure that also requires moving internal components so that they still fit, requiring minor changes to the internal board and firmware). No other changes are permitted (even to incorporate other non-security relevant changes such as bug fixes). In Web Cryptik, this may be captured as a checkbox under the PHYS submission scenario (e.g., the CSTL selects "Limited NSRL").

7.1.14 Submission Scenario Summary Table

Scen-ario	Active or Hist-orical[1]	New or Updated Cert[2]	New Sun-set Date[3]	Meet All Latest Guidance[4]	Code changes[9]	CAVP[10]	ESV[5]	ENT Remain on Cert[7]	Pre-defined Regres-sion Testing[8]	Existing OEs Re-tested[11]
INTU	A or H	New	Yes	Yes	No	No	No	No	No	No
VUP	A or H	Updated	No	No	No	No	No	Possible	No (nor optional)	No
VAOE	A or H	Updated	No	No	No	No	No	Possible	No (nor optional)	No
NSRL	A only	Updated	No	No	Limited	No	No	Possible	No	Yes on at least one OE
ALG	A only	Updated	No	No (except for the updated algorithm)	No	Yes (updated alg)	No	Possible	No	No
OEUP	A only	Updated	No	No	Limited	Yes (new OEs)	Yes[6]	Possible	Yes (full)	No
RBND	A only	New	No	No	Limited	No	No	Possible	No (nor optional)	No
PTSC	A only	New	No	No	Limited	Yes (new OEs)	Yes[6]	Possible	Yes (full)	No
UPDT	A or H	New	Yes	Yes	< 30 %	Yes	Yes	No	Yes (full)	Yes on all OEs
CVE	A or H	Updated	No	No	Limited	Possible	No	Possible	Yes (subset)	Yes on all OEs
TRNS	A or H	New	No	No (except for the algorithm transitioning)	Limited	Possible	No	Possible	Yes (subset)	Yes on at least one OE
PHYS	A only	Updated	No	No	No	No	No	Possible	Yes (physical security)	N/A
FS	N/A	New	Yes	Yes	N/A	Yes	Yes	No	Full testing	N/A

[1] A or H means the revalidation can be on a completed validation that is either Active *or* Historical; A only means it can only be on an Active validation.

[2] The result of this validation or revalidation will either be a new certificate (new number) or an updated certificate (same number).

[3] The result of this validation or revalidation will either be a new sunset date of 5 years, or the sunset date will remain the same. See Additional Comment #3 below for more details.

[4] If Yes, the validation or revalidation **shall** meet all the latest applicable guidance and requirements (e.g., standards, implementation guidance, management manual guidance, algorithm testing/self-tests, and other CMVP guidance) at the time of submission to the CMVP unless there is an implementation guidance transition that affects reports in the queue. For an INTU, this applies only for the documentation changes, not the testing requirements. If No, the revalidation **shall** meet all applicable requirements at the time of *original* validation (a module does not need to meet requirements that were added since the time of original validation, except those specified in the table).

[5] Is ESV testing required (if applicable per IG 9.3.A)?

[6] Only required on the new OEs for OEUP, or new single-chip environments for PTSC.

[7] Only for the original validation's ENT claim. No new ENT claims are possible, for any validation or revalidation.

[8] Note: additional regression testing (on top of the predefined ones) may be applicable per requirements of the scenario. See the CMVP FIPS 140-3 Resources page for the pre-defined regression tests.

[9] Are code changes permitted?

[10] Is CAVP testing required?

[11] Is re-testing on existing OE(s) required?

7.1.15 Additional Comments

1. If the individual section(s) security level is being lowered as part of the revalidation, this is considered security relevant and the module may be submitted as a UPDT with full testing on the individual section(s) that is being lowered or impacted by the change.
2. If the individual section(s) security level is being raised or if the physical embodiment changes, e.g., from multi-chip standalone to multi-chip embedded, then the cryptographic module will be considered a new module and **shall** undergo full validation testing by a CSTL and submitted as an FS.
3. The sunset date for the module is determined based on the scenario:
    - Scenarios FS, UPDT – sunset date will be 2 years (interim validation) or 5 years (full validation) from the date the module was validated
    - Scenarios VUP, VAOE, NSRL, ALG, OEUP, CVE, PHYS – sunset date unchanged
    - Scenarios RBND, PTSC, TRNS – sunset date is inherited from the original certificate
4. It is **not** possible to combine any revalidation scenarios outside of what is explicitly permitted by the submission scenario. For example, if a vendor would like to rebrand

(RBND) a PTSC submission, this would need to happen in two separate submissions (i.e., RBND followed by a PTSC). Similarly, despite it being a simple change, a VUP or VAOE would need to be submitted separately and cannot be combined with other scenarios (besides FS and UPDT). This will give the CMVP the most flexibility to address each scenario submission effectively and efficiently.

A summary table of the permitted combinations are below:

Main Submission \ Secondary scenario	VUP	VAOE	NSRL	ALG	OEUP	RBND	PTSC	UPDT	CVE	TRNS	PHYS
VUP	-	-	-	-	-	-	-	-	-	-	-
VAOE	-	-	-	-	-	-	-	-	-	-	-
NSRL	-	-	-	-	-	-	-	-	-	-	-
ALG	-	-	-	-	-	-	-	-	-	-	-
OEUP	-	-	✓	x	-	-	-	-	-	-	-
RBND	x	-	✓	-	-	-	-	-	-	-	✓
PTSC	-	-	✓	✓	-	-	-	-	-	-	-
UPDT	✓	✓	x	✓	✓	✓	✓	-	✓	✓	✓
CVE	-	-	✓	✓	-	-	-	-	-	-	-
TRNS	-	-	✓	✓	-	-	-	-	-	-	-
PHYS	-	-	✓	-	-	-	-	-	-	-	-

x - The secondary scenario will NOT be separately selectable as a sub-option in WebCryptik (e.g., VUP changes are always part of a RBND).
✓ - The secondary scenario WILL be separately selectable as a sub-option but will likely be further locked down / limited per the Main Submission scenario guidance (e.g., NSRL changes associated with an OEUP submission must be specific to running the new OEs, rather than permitting *any* NSRL changes).

For the revalidation scenarios that *can* be combined (i.e., checkbox in the table above), the main submission **shall** meet all applicable requirements of the secondary scenario, in addition to the main scenario requirements, and document both scenarios in the Change Document. For example, in addition to the RBND requirements, a RBND + NSRL must document and include all NSRL regression testing as applicable.

5. A revalidation submission cannot be performed on a submission that is in the queue. It **shall** be on a completed validation (e.g., UPDT on a *validated* FS). However, see sections 4.3.5 (*Resubmission while in Pending Review*) and 4.3.6 (*Changes while in Coordination*) for permitted changes while in the queue within the same submission.

7.2 CMVP requirements pertaining to testing and approved algorithms

FIPS 140-3 describes approved security functions which can be used in an approved mode of operation, and non-approved security functions which cannot be used in an approved mode of operation. Approved security functions are expected to be CAVP tested, but CAVP testing may rarely not yet be available for these methods.

In such cases where CAVP testing is not available, guidance must be written to permit using these algorithms in an approved mode. These algorithms may be "vendor affirmed" to meet the applicable standard(s).

In addition, security methods that fall outside of the list of approved methods cannot be used in an approved mode, unless guidance is written to permit such special cases, where these methods are *allowed* to be used in the approved mode of operation; or as permitted under AS02.21.

The next two sections explain when vendor affirmed or *allowed* methods are permitted, as well as the transitioning from vendor affirmed to CAVP Testing.

7.2.1 Vendor Affirmation of Security Functions and Methods

If CAVP testing is not available or the module is submitted during a transition period, then the following guidance is applicable.

If new approved methods (e.g., NIST FIPS, SP, etc.) are added to SP 800-140 documents, until such time that CAVP testing is available or the transition period has not yet expired for the new method, the CMVP may:

- permit vendor affirmation of the new approved method if supported by existing IG(s) (untested, listed as approved for use in an approved mode with the caveat "vendor affirmed"). If no such IG is published, vendor affirmation is not possible.

Notes:

1. The Cryptographic Technology Group (CTG) at NIST may determine prior methods may be retroactively disallowed and moved to non-approved and not permitted in an approved mode of operation (e.g., DES). A transition notice would appear in NIST publications.
2. For all approved methods, all applicable FIPS 140-3 requirements must be met.
3. The CMVP may decide to *allow* methods in the approved mode that are non-approved with supported by existing IG(s) (untested, and listed as non-approved but *allowed* in an approved mode; e.g., see IGs D.F and D.G).
4. **Vendor Affirmed**: a security method reference that is listed with this caveat has not been tested by the CAVP, and the CMVP or CAVP provide no assurance regarding its correct implementation or operation. Only the vendor of the module affirms that the method or algorithm was implemented correctly.
5. The users of cryptographic modules implementing vendor affirmed security functions must consider the risks associated with the use of untested and unvalidated security functions.

7.2.2 Transitioning from vendor affirmed to CAVP Testing

When CAVP algorithm testing is released on the ACVTS production server in any of the following 3-month periods identified below, the transition occurs at the end of the following 3-month transition date. More specifically:

CAVP testing release	CMVP report submitted by
Jan 1 – March 31	June 30
April 1 – June 30	Sept 30
July 1 – Sept 30	Dec 31
Oct 1 – Dec 31	March 31

Table 1 - CAVP testing release dates and subsequent CMVP Transition dates

To illustrate, if the CAVP releases new testing for algorithm A, B and C, during the July 1 – September 30 period, then the transition date will be September 30 + three months, so after December 31 vendor affirming to algorithms A, B, or C will be prohibited in initial report submissions.

During the transition period, a new approved method would either be listed as approved with a reference to a CAVP validation certificate, or as vendor affirmed if testing was not performed and an IG that supports vendor affirmation of this algorithm was met.

When the transition period ends, for newly received test reports:

- only approved methods that have been tested, receives a CAVP validation certificate and is verified to meet the underlying algorithm standard is permitted. All other methods would be listed as non-approved and not allowed in an approved mode of operation.
- the vendor could optionally follow up with testing of untested vendor affirmed methods and if so, the reference to vendor affirmed would be removed and replaced by reference to the algorithm certificate. If there are no changes to the module, this change can be submitted under Scenario ALG (see Section 7.1 – *Submission Scenarios*). If the module is changed, this can be submitted under Scenarios UPDT or FS as applicable.

Note: To track the algorithms and their transition dates, the CMVP maintains a table available on (https://csrc.nist.gov/Projects/cryptographic-module-validation-program/programmatic-transitions).

Note: If a self-test requirement is associated with the algorithm, the algorithm will only be considered as an approved algorithm by CMVP if the self-test requirement is also met.

7.3 Testing using Emulators and Simulators

Under certain circumstances it may not be possible to test a module or algorithm directly. In these cases, CMVP has permitted the use of emulators and simulators to model the behavior of

the item being tested. It is important to note the differences of these models and to apply them under the correct circumstances.

An emulator attempts to “model” or “mimic” the behavior of a cryptographic module. The correctness of the emulators' behavior is dependent on the inputs to the emulator and how the emulator was designed. It is not guaranteed that the actual behavior of the cryptographic module is identical, as other variables may not be modeled correctly or with certainty.

A simulator exercises the actual source code (e.g., Very High-Speed Integrated Circuit (VHSIC) Hardware Description Language (VHDL) code) prior to physical entry into the module (e.g., a Field-Programmable Gate Array (FPGA) or custom Application-Specific Integrated Circuit (ASIC)). From a behavioral perspective, the behavior of the source code within the simulator may be logically identical when placed into the module or instantiated into logic gates. However, many other variables exist that may alter the actual behavior (e.g., path delays, transformation errors, noise, environmental, etc.). It is not guaranteed that the actual behavior of the cryptographic module is identical, as many other variables may not be identified with certainty.

Labs may apply emulators or simulators depending on the type of testing results to be achieved. There are three broad areas of focus during the testing of a cryptographic module: operational testing of the module at the defined boundary of the module, algorithm testing and operational fault induction testing.

1. Operational Testing – Emulation or simulation is prohibited for the operational testing of a cryptographic module. Actual testing of the cryptographic module must be performed utilizing the defined ports and interfaces and services that a module provides. A test harness or a modified version to induce an error may be utilized; however, no changes to code or circuitry responsible for the tested response may be made.
2. Operational Fault Induction – An emulator or simulator may be utilized for fault induction to test a cryptographic module’s transition to error states as a complement to the source code review. Rationale must be provided for the applicable TE as to why a method does not exist to induce the actual module into the error state for testing.
3. Algorithm Testing – Algorithm testing utilizing the defined ports and interfaces and services that a module provides is the preferred method. This method most clearly meets the requirements of IG 2.3.A. If this preferred method is not possible where the module’s defined set of ports and interfaces and services do not allow access to internal algorithmic engines, two alternative methods may be utilized:
    a. A module may be modified under the supervision of the CSTL for testing purposes to allow access to the algorithmic engines (e.g., test jig, test API), or
    b. A module simulator may be utilized.

    When submitting the algorithm test results to the CAVP, the actual OE on which the testing was performed must be specified (e.g., including modified module identification or simulation environment). When submitting the module test report to the CMVP, AS2.20 must include rationale explaining why the algorithm testing was not conducted on the actual cryptographic module. An emulator may not be used for algorithm testing.

7.4 Remote Testing of Modules

The guidance below addresses the need for testing a module remotely while obtaining the equivalent assurance as if the test were performed at the **vendor's facility**. All physical security testing except for Environment failure protection/testing (i.e., EFT/EPT tests: TE.07.73.01, TE.07.77.01-03 and TE.07.81.01-02) **shall** be performed in person by a CSTL tester at either the vendor site, the CSTL site and/or remote site as per HB 150-17 requirements.

The CSTL may perform some or all testing remotely. If the testing is performed remotely at the vendor site, the following conditions **shall** be met:

1. a. The hardware, firmware or hybrid IUT is located at the vendor site.

   b. The software IUT is located at the vendor site or 3rd party cloud system.

2. The vendor remotely provides a cryptographic module to the test laboratory and its boundary and version are verified against the Security Policy. (ISO/IEC 24759 TE04.13.01, 02, 03). The module boundary and version **shall** be verified at the beginning of any new remote testing sessions.

3. a. The network access and/or video conference to a remote test operational environment, in support of actual testing, **shall** be authorized and controlled by the vendor.

   b. A 3rd party cloud system (e.g., Amazon Web Services, Microsoft Azure, and Google Cloud) may be used as a service in support of module validation (e.g. video conference and data storage) if:

   - all HB 150-17 and NVLAP General Criteria Checklist ISO_IEC 17025 requirements are met; and
   - the remote testing requirements are met.

   c. A 3rd party cloud system (e.g., Amazon Web Services, Microsoft Azure, and Google Cloud) may be used as a testing platform if:

   - all HB 150-17 and NVLAP General Criteria Checklist ISO_IEC 17025 requirements are met;
   - the remote testing requirements are met;
   - the environment provides the same level or additional level of security as the lab would provide for internal testing;
   - the cryptographic module under test **shall** be confirmed to be running on an OE that is well-defined and has a specific OS version, hardware platform and version, and processor (including microprocessor version) as shown on the module's certificate and security policy; and
   - the OS version, hardware platform and version, and processor **shall** be confirmed during the testing session.

d. As permitted within a signed agreement by the lab and vendor:

- The tester's network **shall** be connected to the vendor's network via a secure connection (e.g., VPN or SSH) ; and/or
- A secure video conference **shall** be used and the recording done in a secure manner.

e. The tester's tools must satisfy the lab's network requirements before connecting to the vendor's network to test the module if applicable.

4. The CSTL **shall** have a procedure for conducting remote testing at the vendor site which includes the following:

   a. All the remote testing sessions that produce the final test results **shall** be recorded and archived at the CSTL as evidence material to demonstrate the tester control and/or oversight (as per bullet 6 below) (e.g. video conference records and/or detailed test plan) and to capture the test results (e.g. video conference records, screenshots and/or log files).

   b. If multiple remote testing sessions are required, a log which includes the date and the test being conducted **shall** be maintained and archived.

   c. If during testing, the IUT version or subversion (e.g. pre-release, debug) changes, the final test report being submitted **shall** reflect the final version of the IUT.

   d. If there are multiple simultaneous testing activities occurring at the vendor site, a system of separation between the different cryptographic module test activities **shall** be maintained.

   e. For all conformance testing and validations, the CSTL **shall** ensure that any file containing iterative, not final, test results are isolated from the final test results.

   f. It is the CSTL's responsibility to ensure that any version iteration during the testing doesn't impact any of the final results transmitted to the CMVP.

5. The required operational environment information (e.g., operating system name and version, processor family, hardware platform model) **shall** be obtained and verified against the operational environment information listed on the CAVP algorithm certificates for this module.

6. The tester is accountable and therefore **shall** understand, oversee, direct, and/or assume control of testing operations to initialize, install, and operate the module. The tester is accountable to ensure the proper initialization, installation and operation of the module through the entire testing at the CSTL site and/or vendor site for the multiple testing sessions as applicable.

7. If a test harness is used, it **shall** be reviewed or written by the lab. It **shall** be verified to have been maintained properly with no vendor manipulation prior to its execution. The test results on the remote operational environment **shall** be captured and transmitted back to lab without the risk of being modified. The tester **shall** verify the test harness runs

properly on its operational environment. The tester must verify the integrity of the testing session as well as the completeness and accuracy of the test results.

8. The remote testing **shall** cover the same set of FIPS 140-3 requirements including but not limited to the following list, as if the operational environment were local to the tester:
   a. The services listed in the module Security Policy can be invoked or directed/overseen and verified by the tester.
   b. For a module to be validated at Level 2 or 3 for ISO/IEC 19790:2012 Section 7.4.4, the role-based or identity-based authentication **shall** be performed or directed/overseen and verified by the tester.
   c. The failure of self-tests and the subsequent transition to an error state where module data output interfaces are inhibited can be observed and verified by the tester.
   d. As applicable per IG 9.3.A, entropy has been effectively analyzed and received an ESV for all specific OEs and/or platforms prior to submission.

The vendor must provide a signed affirmation letter to the lab describing the remote testing process and access control mechanism that allows the lab to perform the test on the remote operational environment and protects the integrity of the test results. The lab **shall** provide a signed letter to the CMVP stating that the module had been tested remotely, affirming that the vendor provided their affirmation letter, stating what TEs were tested remotely, and explaining how the requirements were met during the remote testing.

It is the CSTL's responsibility to ensure that the assurance level is maintained when remote testing is being conducted.

Additional Comments:

1. It is the responsibility of the tester to determine if a module is eligible to be tested remotely. If the tester cannot demonstrate a test requirement during remote testing, then the module **shall** not be fully tested remotely. If the tester wishes to test a subset of test requirements remotely, the remaining test requirements **shall** be tested onsite at the CSTL site or in person by the CVP tester at the vendor site.

2. The tester **shall** confirm that the operational environment exactly matches the agreed upon test environment, including any virtual environments used. A Virtual Machine may not be used in lieu of an OS, unless the VM has been agreed to be part of the test environment and will be listed on the certificate.

3. A record of the testing location, related documentation (e.g. equipment proof of calibration) and CSTL tester(s) who conducted the testing **shall** be maintained. This is applicable for all tests including physical security testing.

4. The above vendor site remote testing requirements are also applicable to 3rd party remote site in addition to existing the HB 150-17 and NVLAP General Criteria Checklist ISO_IEC 17025 requirements.

5. Regardless of the location of the testing, it is the CSTL's responsibility to ensure that all HB 150-17 and NVLAP General Criteria Checklist ISO_IEC 17025 requirements are met (e.g. NVLAP General Criteria Checklist ISO_IEC 17025: **6.4.2, 6.4.3,** 6.4.6, 6.4.7, 6.4.8, **7.1.4** requirements; and HB 150-17 B.2.2 & B.3 requirements).

6. Regarding any ITAR related questions, please refer to https://www.ecfr.gov/current/title-22/chapter-I/subchapter-M/part-120/subpart-C/section-120.54.

7.5 Partial validations and non-applicable areas

CMVP will not issue a validation certificate unless the cryptographic module meets at least the Security Level 1 requirements for each area in Section 6 of ISO/IEC 24759:2017. Areas can be designated as Not Applicable (N/A) if they meet the following criteria:

- Section 6.5, Software/Firmware Security may be designated as N/A if the module is hardware-only without firmware (or software);
- Section 6.6, Operational Environment may be designated as N/A if the operational environment for the cryptographic module is a limited or non-modifiable operational environment and Section 6.7, Physical Security is greater than Security Level 1 (AS06.04).
- Section 6.7, Physical Security may be designated as N/A if the cryptographic module is a software-only module and thus has no physical protection mechanisms;
- Section 6.8, Non-invasive security is N/A by default as there are currently no requirements in SP 800-140F. Any claims for non-invasive will be identified under Section 6.12.
- Section 6.12, Mitigation of Other Attacks is Applicable if the module has been purposely designed, built, and publicly documented to mitigate one or more specific attacks (see IG 12.A). Otherwise, this section may be designated as N/A.

7.6 CMVP requirements for PIV validations

PIV card applications can only be tested on a CMVP validated module, such as a smartcard. The CMVP validated module then obtains NPIVP validation, by adding the PIV card application to the module. The validated smartcard and the PIV card application is then re-validated as a CMVP module.

A PIV card application that is included as a component of a cryptographic module **shall** be referenced on the module validation. The cryptographic module validation entry **shall** provide reference to the PIV card application(s) validation certificate number. The cryptographic module's versioning information **shall** include the complete versioning information of the module including the PIV application(s). Each PIV application's name **shall** be clearly identified, and the PIV Certificate number is referenced on the CMVP module validation.

The PIV NPIVP validation entry includes the following information:

1. the name of the PIV card application,

2. the name of the cryptographic module the PIV application was tested on, and
3. the complete versioning information of the module including the PIV application(s)

The NPIVP validation entries can be found at:

https://csrc.nist.gov/projects/nist-personal-identity-verification-program/validation-lists/piv-card-application-validation-list

7.7 Module count definition

Moved to the following CMVP webpage (under "MIS Field Descriptions"):
https://csrc.nist.gov/projects/cmvp/sp800-140b

7.8 Module definitions for same certificates

To be on the same certificate, each module version **shall** have identical:

1. Section and overall levels.
2. Suite of approved security services.
3. Cryptography.
4. Suite of security functions and underlying algorithms, modes, and key sizes. This includes the entropy source, unless the entropy source is outside of the module boundary but within the TOEPP in which case there may be multiple ESVs that map to multiple tested OEs.
5. Suite of SSPs associated with the security services.
6. Suite of roles and authentication methods.
7. Finite State Model except related to the allowed differences.
8. SSP establishment methods.
9. Suite of self-tests.
10. Life-cycle assurance.
11. Mitigation of other attacks.
12. Module type (i.e., Software, Hardware, Firmware, or Hybrid).
13. Module embodiments (i.e., single-chip, multi-chip embedded/standalone) with similar physical construction including physical boundary.

7.9 Vendor or User Affirmation of Modules

The tested/validated module version, OE upon which it was tested, and the originating vendor are stated on the validation certificate entry. The certificate validation entry serves as the benchmark for the module-compliant configuration. This guidance addresses two separate scenarios: changes a **Vendor** (7.9.1) can affirm the module will perform as tested in the CSTL's validation submission and changes a **User** (7.9.2) can affirm the module will perform as tested in the CSTL's validation submission.

This guidance is *not applicable* for validated modules when the requirements of **ISO/IEC 19790:2012** Section 7.7 Physical Security has been validated at Levels 2 or higher. This guidance is however, applicable at Physical Security Level 1 for *firmware* or *hybrid* modules.

7.9.1 **Vendor**

1. A vendor may perform post-validation recompilations of a software, firmware, or hybrid module and affirm the modules continued validation compliance. By adding vendor support of non-tested configurations to the validated module security policy, the vendor bears all responsibility. These non-tested configurations versions may be considered by the user at their risk, provided the following is maintained:

   a) Software modules do not require any source code modifications (e.g., changes, additions, or deletions of code) to be recompiled and ported to another OE and must:

      i) For **Level 1 OE**, a software cryptographic module can be considered compliant with the FIPS 140-3 validation when operating on any general-purpose platform/processor that supports the specified operating system as listed on the validation entry or another compatible[4] operating system, or

      ii) For **Level 2 OE**, a software cryptographic module can be considered compliant with the FIPS 140-3 validation when operating on any general-purpose platform/processor that supports the same level 2 operational environment settings specified on the validation entry.

   b) Firmware modules do not require any source code modifications (e.g., changes, additions, or deletions of code) to be recompiled, and its identified unchanged tested operating system (i.e., same version or revision number) may be ported together from one platform to another platform while maintaining the module's validation.

      Level 2 and above Firmware modules cannot be ported and maintain their validation, since Physical Security must be retested.

   c) Hybrid modules may be ported together from one OE to another OE while maintaining the module's validation provided that they do not require any of the following:

      i) software or firmware source code modifications (e.g., changes, additions, or deletions of code) to be recompiled and its identified unchanged tested operating system (i.e., same version or revision number) or another compatible operating system;

      ii) modified hardware components utilized by the software or firmware (e.g., changes, additions, or deletions).

      Level 2 and above hybrid modules cannot be ported and maintain their validation, since Physical Security must be retested.

   The CMVP allows vendor porting and re-compilation of a validated software, firmware or hybrid cryptographic module from the OE specified on the validation certificate to an OE which was not included as part of the validation testing as long as the porting rules are followed. Vendors may affirm that the module works correctly in the new OE. However, the CMVP makes no statement as to the correct operation of the module or the security strengths

[4] Compatibility may be based on how the module is compiled (e.g., for a specific processor, or general purpose). General purpose (universal) can be ported to other OEs. OSs of the same "family" could be another example of compatibility.

of the generated keys when so ported if the specific OE is not listed on the validation certificate.

The vendor **shall** work with a CSTL to update the security policy and submit it to the CMVP under one of the available revalidation scenarios (see submission scenario VAOE in Section 7.1). The update would affirm and include references to the new vendor affirmed OE(s) (see related table in SP 800-140B and SP 800-140Brev1). The module's Security Policy **shall** include a statement that no claim can be made as to the correct operation of the module or the security strengths of the generated keys when ported to an OE which is not listed on the validation certificate.

2. Software or firmware modules that require source code modifications (e.g., changes, additions, or deletions of code) to be recompiled and ported to another hardware or OE must be reviewed by a CSTL and revalidated per Section 7.1 (including regression testing) to ensure that the module does not contain any OE-specific or hardware environment-specific code dependencies. See Scenarios UPDT, NSRL, and OEUP. This is not porting or vendor affirming the OE but rather incorporating the new versions and environment onto the certificate.

The vendor must meet all applicable requirements in ISO/IEC 19790:2012 Section 7.11 Life-cycle assurance, SP 800-140 Section 6.11 Life-cycle assurance and related CMVP IGs.

7.9.2 User

A user may not modify a validated module. Any user modifications invalidate a module validation. [5]

A user may perform post-validation porting of a module and affirm the module's continued validation compliance provided the following is maintained:

1. For **Level 1 OE**, a software, firmware, or hybrid cryptographic module will remain compliant with the FIPS 140-3 validation on any general-purpose platform/processor that supports the specified operating system listed on the validation entry, or another compatible operating system.

The user may affirm that the module works correctly in the new OE if the porting rules are followed. However, the CMVP makes no statement as to the correct operation of the module or the security strengths of the generated keys when ported and executed in an OE not listed on the validation certificate.

7.10 Operational Equivalency Testing for HW Modules

CMVP requires full testing of any module that the vendor wishes to list on the certificate. However, modules may be grouped together if they are the same except for devices listed under

[5] A user may post-validation recompile a module if the unmodified source code is available and the module's Security Policy provides specific guidance on acceptable recompilation methods to be followed as a specific exception to this guidance. The methods in the Security Policy must be followed without modification to comply with this guidance.

Equivalence Categories, which are currently considered for five classes of devices. Each Category and sample technologies for each Category are provided in Table 2.

Category	**Examples**
Memory/Storage Devices	○ HDD, SSD, DRAM, NAND, NOR, ROM, Solid State Memory Device, USB Flash Drive ○ Optical Disk Drive ○ Magnetic Tape Drive
Field Replaceable and Stationary Accessories	○ Power Supplies ○ Fans
Interfaces (I/O Ports)	○ Port Count ○ Line Card Count ○ Serial: RS232, RS422, RS485 ○ SAS, SATA, eSATA ○ Fiber Optic, FCoE, Fiber Channel ○ Ethernet, FireWire, DVI, SCSI, USB
Computational Devices	Refer to CAVP equivalency criteria and entropy constraints for guidance
Programmable Logic Devices	○ CPLD, FPGA, PAL

Table 2 - Equivalence Categories

For details on the Equivalency Categories, please see the Equivalency Categories Tables under the FIPS 140-3 Resources Tab of the CMVP website. Also note, for modules that have differences within each of those categories, the level of testing required is dependent on the differences. Some differences require analysis only, while others require full or limited regression testing. The following are the general categories of the levels of testing. The actual testing required depends on the Equivalency Category (See Equivalency Regression Test Table and Equivalency Categories Tables found under the FIPS 140-3 Resources Tab of the CMVP website):

- Analysis Only (AO) for Equivalency Category X: Once the equivalency evidence/argument is provided and validated for the Equivalency Category X, there is no additional test other than the proof of its physical existence required on a module with the equivalent components in Category X to the module that has been fully tested under the same validation.
- Required Testing (RT) for Equivalency Category X:

- If a module has some security relevant differences in the Equivalency Category X, the module **shall** be tested against all of the listed TEs for that category in Equivalency Regression Test Table found under the FIPS 140-3 Resources Tab of the CMVP website.
- If a module claims equivalency in multiple categories in comparison to a fully tested module under the same validation, all of the required TEs for each claim equivalency category **shall** be satisfied.

- Focused Testing (FT) for Equivalency Category X:
  - The use of some technologies may introduce Security Relevant differences that cannot be predicted by this Section 7.10. For example, Programmable Logic Devices may be used to support the Cryptographic Module in a number of different ways that are security relevant (e.g., authentication). It is up to the lab to determine what section of the standard is affected by this security relevant difference and apply the Revalidation Regression Test Table found under the FIPS 140-3 Resources Tab of the CMVP website. For other sections not affected by this difference, Regression Testing per Equivalency Regression Test Table found under the FIPS 140-3 Resources Tab of the CMVP website shall be performed.
- Complete Regression Testing (CRT): If an equivalency justification cannot be made, or the module differences can be mapped to a CRT entry within Equivalency Categories Tables under the FIPS 140-3 Resources Tab of the CMVP website, all modules, which lack an equivalency justification must, according to their security level, satisfy each TE listed in the Revalidation Regression Test Table under the FIPS 140-3 Resources Tab of the CMVP website.

In each report where the vendor wishes to claim equivalency, the lab **shall**:

- List the Equivalency Category, and specific component types being claimed in TE02.15.01. The lab must justify the component categorizations. The assumption is that the vendor initiated the Equivalency Category argument while the lab performed the analysis.
- List the additional testing performed (if any) between the modules. This list **shall** be provided as an addendum to the test report.
- Include in the Test Report how each module meets the TE's that are required for testing per this Section 7.10.

For example:

- Two devices to be on the same certificate have Hard Drives with different storage capacities, so testing requirement is Analysis Only, e.g., proof that both modules exist as claimed by the vendor.
- Two devices to be on the same certificate have different types of Solid State Memory: one has NOR Flash and the other has NAND. This will require a small selection of testing, per Equivalency Regression Test Table found under the FIPS 140-3 Resources Tab of the CMVP website.
- Two devices to be on the same certificate have different types of storage: one has a Hard Disk and the other has a Solid-State Drive. This will require complete regression testing per Revalidation Regression Test Table.

Additional Comments

- The lab **shall** perform full testing on at least one module.
- This only applies to Operational testing of Hardware modules
- Physical security testing (ISO/IEC 19790:2012, section 7.7) is not addressed for Security Level 2 and above. In other words, this does not exempt the lab from performing physical security testing for modules at Level 2 or above. This is because the lab needs to examine each module for, e.g., opacity and tamper evidence, if there are physical differences between the modules.
- Components considered equivalent may still affect the entropy generated within the modules in different ways. This must be accounted for in the ESV report, if ESV is applicable.
- Equivalency considerations of the main processors/CPUs are out of scope of this Section 7.10. If the CPU is different between modules on the same certificate, then the full Revalidation Regression Test Table must be run (found under the FIPS 140-3 Resources Tab of the CMVP website).
- ISO/IEC 24759:2017 Section 6.7 Physical Security, Section 6.8 Non-Invasive Security and Section 6.12 Mitigation of Other Attacks are out of scope of this guidance.

Annex A CMVP Post Validation Issue Assessment Process

Annex A.1 Addressing Security Relevant Issues

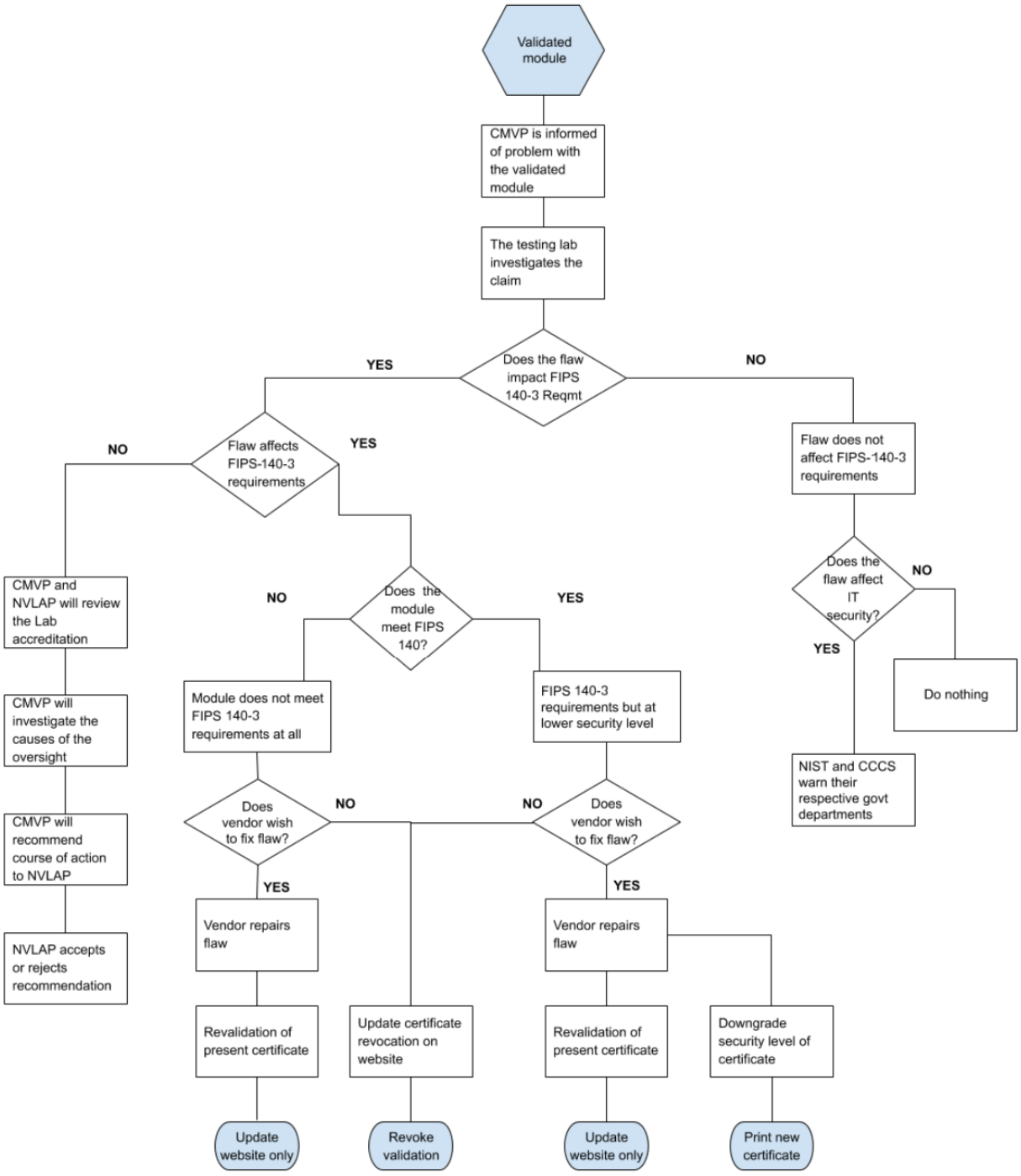


Figure 5- Annex A. Validation Issue Assessment Process

Annex A.2 Addressing CVE Relevant Vulnerabilities

The list of CVEs is maintained by NIST in the NVD at https://nvd.nist.gov/. The purpose of the Scenario CVE revalidation (described in Section 7.1) is to provide the vendor a means to quickly fix, test and revalidate a module that is subject to a security-relevant CVE, while at the same time providing assurance that the module still meets the current FIPS 140 standards.

Vendors must reference this database and address the security relevant CVE's that are within the boundary of the module, not only during the validation process, but also after the module has been validated. Without published security relevant CVEs being addressed by the vendor and verified by the testing laboratory, the CMVP has no assurance that the module meets the requirements to obtain or maintain validation.

At the discretion of the CMVP, certificates will be revoked that do not comply. It is the goal of the CMVP to maintain the security of validated modules.

For more information about CVEs please also refer to https://cve.mitre.org/. See also IG 11.A *CVE Management* for more guidance on this topic.

ACRONYMS

ACVTS	Automated Cryptographic Validation Testing System
ANSI	American National Standards Institute
AS	Assertion
CAVP	Cryptographic Algorithm Validation Program
CCCS	Canadian Centre for Cyber Security
CMVP	Cryptographic Module Validation Program
CMUF	Cryptographic Module User Forum
CR	Cost Recovery
CSTL	Cryptographic and Security Testing Laboratory
CVC	Consolidated Validation Certificate
CVE	Common Vulnerabilities and Exposures
CVP	Cryptographic Validation Program
DES	Data Encryption Standard
ECR	Extended Cost Recovery
ESV	Entropy Source Validation
FIPS	Federal Information Processing Standard
FISMA	Federal Information Security Management Act
FSM	Finite State Model
GC	Government of Canada
HB	Handbook
ID	Identification
IG	Implementation Guidance
ISO	International Organization for Standardization
ITAR	International Traffic in Arms Regulation
IUT	Implementation Under Test
N/A	Not Applicable
NIST	National Institute of Standards and Technology
NVLAP	National Voluntary Laboratory Accreditation Program
OE	Operational Environment
OS	Operating System
PDF	Portable Document Format

2749	**RFG**	Request for Guidance
2750	**SP**	Special Publication
2751	**TE**	Tester Evidence
2752	**TID**	Tracking Identification Number
2753	**TR**	Test Requirements
2754	**URL**	Uniform Resource Locator
2755	**VE**	Vendor Evidence